

Universidad Nacional del Altiplano

UNIVERSIDAD NACIONAL DEL ALTIPLANO DE PUNO

Trabajo 01 · Unidad I

Plan de ciberseguridad

Gestión del riesgo, inteligencia de amenazas y validación técnica de controles

NIST CSF 2.0 · STRIDE · MITRE ATT&CK
Threat Intelligence · Cyber Kill Chain · Zero Trust

Docente: Ing. Fidel Ernesto Ticona Yanqui

Estudiante: Alfonte Tarqui Rendo

Asignatura: Tópicos de Ciberseguridad

Repositorio del proyecto
`https://github.com/ForLess01/ProyectoUnitI`

Propuesta académica aplicada
Investigación institucional y ejecuciones reales en laboratorio aislado

Puno, Perú
18 de octubre de 2026

Resumen

El plan articula la protección de los servicios académicos y administrativos de la Universidad Nacional del Altiplano de Puno (UNA Puno) mediante seis enfoques complementarios. NIST CSF 2.0 organiza la gestión; STRIDE estructura las amenazas de diseño; la inteligencia de amenazas aporta hechos externos; MITRE ATT&CK describe comportamientos adversarios; Cyber Kill Chain relaciona etapas y oportunidades de interrupción; y Zero Trust orienta decisiones de acceso explícitas.

La investigación verificó fuentes institucionales, el ROF aprobado por la Resolución Rectoral N.º 2212-2025-R-UNA y cinco vistas públicas de servicios universitarios. La Oficina de Tecnologías de la Información (OTI) posee competencias informáticas y de seguridad de la información automatizada; esas competencias no acreditan, por sí mismas, controles desplegados [1, 2].

La validación técnica ejecutó **13 casos funcionales y cuatro flujos de navegador**, todos conformes con sus resultados esperados, en un contenedor limitado a 1 CPU y 256 MiB. Se comprobaron autenticación multifactor TOTP, autorización por rol y objeto, integridad, auditoría, límites de solicitud y revocación de sesión. Además, se ejecutaron descubrimiento, recopilación y preparación local de dos archivos de prueba, con una alerta de la regla local LAB-DET-001, y se restauró una copia alterada verificando SHA-256. Se conservaron **nueve capturas técnicas y cinco capturas institucionales**, comandos, registros y manifiestos de integridad.

La prioridad propuesta es: inventariar y asignar propietarios; proteger identidades privilegiadas; separar accesos y servicios; centralizar registros; y probar restauraciones. El cronograma anual y los indicadores convierten estas prioridades en actividades verificables. Los resultados del laboratorio validan mecanismos en ese entorno y **no constituyen una auditoría ni hallazgos de vulnerabilidades sobre la infraestructura de la UNA Puno**.

Lectura de los resultados

D: documentado, respaldado por una fuente institucional; **E: ejecutado**, medido en el laboratorio; **P: propuesto**, objetivo de implementación; **V: por validar**, información institucional no comprobada. Una clasificación o riesgo propuesto no equivale a una vulnerabilidad confirmada. El documento no atribuye incidentes a la universidad.

Índice

Resumen I
I. Datos generales 1
I.1. Método y calidad de la evidencia 1
II. Introducción 1
III. Finalidad 1
IV. Objetivos 2
IV.1. Objetivo general 2
IV.2. Objetivos específicos 2
V. Alcance 2
V.1. Caso conductor y límites 2
V.2. Base normativa y responsabilidades 3
VI. Inventario y clasificación de activos 3
VI.1. Criterio de clasificación 3
VII. Análisis de amenazas mediante STRIDE 3
VII.1. Componentes, usuarios y límites de confianza 3
VII.2. Procedimiento y evaluación 4

VIII. Inteligencia de amenazas 4
VIII.1. Ciclo de vigilancia 4
VIII.2. Boletín TI-2026-01: corte al 18/10/2026 4
VIII.3. Indicadores y comunicación 5
IX. Análisis con MITRE ATT&CK 5
X. Análisis mediante Cyber Kill Chain 6
XI. Implementación de Zero Trust 6
XII. Matriz NIST CSF 2.0 aplicada 6
XIII. Controles de seguridad 7
XIV. Gestión de incidentes 8
XIV.1. Roles y canal de reporte 8
XIV.2. Flujo operativo 8
XIV.3. Clasificación, escalamiento y notificación 8
XIV.4. Respuestas por escenario 9
XV. Capacitación y concientización 9
XVI. Indicadores de cumplimiento 9
Conclusiones 10
Anexo 1. Inventario de activos y evidencia institucional 11
Anexo 2. Matriz de criticidad 17
Anexo 3. Matriz STRIDE y pruebas desarrolladas 18
Anexo 4. Matriz MITRE ATT&CK y evidencia de ejecución 24
Anexo 5. Cyber Kill Chain y controles por etapa 26
Anexo 6. Matriz Zero Trust, roles, usuarios y permisos 27
Anexo 7. Registro de incidentes y procedimiento reproducible 32
Anexo 8. Cronograma anual 35
Anexo 9. Indicadores de ciberseguridad 36
Anexo 10. Plan de capacitación 39
Glosario de términos y siglas 40
Trazabilidad de cobertura 41
Referencias bibliográficas 42

Índice de figuras

1. Modelo lógico propuesto: los flujos F1–F6 permiten analizar fronteras y controles. . . . 4
2. WEB01. Portal público de la UNA Puno. 12
3. WEB02. Campus Virtual y catálogo público de módulos. 13
4. WEB03. Portal de trámites: comunicado público y contexto del proceso académico. . 14
5. WEB05. Página institucional que publica el ROF. 15
6. WEB06. Página pública del repositorio institucional. 16
7. TERM-01. Ejecución PTY de autenticación y MFA, con terminación 0. 20
8. TERM-02. Autorización por rol y objeto: rechazo lector, acceso administrador y aislamiento A/B. 21
9. TERM-03. Integridad y campos de auditoría contrastados por las pruebas. 22
10. TERM-04. Solicitud limitada y sesión revocada: rechazo esperado y servicio posterior operativo. 23
11. TERM-05. Ejecución real de descubrimiento, recopilación, staging y restauración de archivos. 25
12. BROWSER-01. Contraseña correcta sin segundo factor: acceso no concedido. 28
13. BROWSER-02. Acceso permitido con TOTP y lectura del registro propio. 29
14. BROWSER-03. El lector recibe HTTP 403 al solicitar administración. 30
15. BROWSER-04. La sesión revocada deja de autorizar solicitudes. 31

I. Datos generales

Campo	Contenido
Entidad	Universidad Nacional del Altiplano de Puno, Perú.
Unidad responsable	OTI como unidad técnica de referencia, conforme al ROF, arts. 70–71; coordinación con las unidades propietarias de información [2].
Responsable del plan	Se propone a la jefatura OTI como coordinadora técnica. La aprobación, el propietario del riesgo, el OSCD y el CSIRT requieren designación institucional; no se presume su identidad.
Periodo de vigencia	Doce meses desde una eventual aprobación institucional. El cronograma usa M1–M12 para evitar atribuir una vigencia ya aprobada.
Fecha de elaboración	18 de octubre de 2026.
Fecha de aprobación	No existe aprobación institucional acreditada: documento académico propositivo.
Ámbito	Personas, información, servicios tecnológicos, infraestructura y terceros que sostienen procesos académicos y administrativos.

I.1. Método y calidad de la evidencia

Se siguieron cuatro pasos: revisión de fuentes primarias; delimitación de activos y procesos publicados; modelado y tratamiento de amenazas; y pruebas técnicas de controles sobre un servicio local propio. Cada afirmación utiliza referencias documentales o un identificador de caso. La fecha institucional se expresa en hora de Perú (UTC−5); los registros conservan UTC. Así, una ejecución registrada el 19/10/2026 a las 03:14 UTC corresponde al 18/10/2026 en Perú.

El inventario diferencia servicios públicamente documentados de categorías de infraestructura todavía no verificadas. No se extrapolan números de servidores, usuarios o incidentes. Las capturas se obtuvieron mediante navegación real en Chrome y Playwright [23]. Las de terminal muestran una consola conectada a un pseudoterminal (PTY) que inició procesos reales y conservó su salida y código de terminación. Los originales se mantienen junto a sus hashes; los detalles recortados del informe se identifican como tales.

II. Introducción

La disponibilidad de matrícula y notas, la integridad de certificados y constancias y la confidencialidad de los datos personales sostienen la continuidad y confianza de una universidad pública. Un cambio no autorizado de un documento académico puede afectar derechos y decisiones; una indisponibilidad durante un periodo crítico retrasa trámites; y una cuenta comprometida puede facilitar acceso a información ajena. Por ello, la ciberseguridad debe vincularse al proceso y a su propietario, y no limitarse a adquirir herramientas.

El portal oficial publica enlaces a Campus Virtual, Aula Virtual, trámites de títulos, grados y constancias, repositorio y biblioteca. La página de trámites describe solicitudes virtuales, seguimiento y modalidades de entrega. Esto sustenta el contexto funcional del caso, pero no permite conocer la arquitectura interna, las bases de datos ni los controles de esos sistemas [1]. El plan utiliza ese contexto real y una validación técnica separada para demostrar cómo comprobar controles antes de su adopción institucional.

III. Finalidad

Establecer medidas organizativas y técnicas para prevenir, detectar, responder y recuperarse de incidentes que afecten a los servicios de la UNA Puno. El resultado buscado es una gestión trazable:

cada riesgo debe tener propietario, tratamiento, evidencia de eficacia y revisión; cada incidente debe producir decisiones de contención, recuperación y aprendizaje.

IV. Objetivos

IV.1. Objetivo general

Fortalecer la seguridad de la información y la continuidad de los servicios universitarios mediante identificación de activos críticos, análisis de amenazas, controles verificables y capacidad de detección, respuesta y recuperación.

IV.2. Objetivos específicos

1. Identificar y clasificar activos y propietarios, incluyendo infraestructura, servicios, información y terceros.
2. Determinar amenazas y condiciones de vulnerabilidad mediante STRIDE y evaluación del riesgo.
3. Analizar comportamientos de atacantes con ATT&CK y oportunidades de interrupción con Kill Chain.
4. Detectar amenazas relevantes a partir de fuentes verificadas y eventos técnicos, sin confundir avisos externos con incidentes institucionales.
5. Implantar progresivamente controles preventivos según criticidad y comprobar su eficacia.
6. Fortalecer identidades y accesos mediante MFA, privilegio mínimo, revisión y revocación.
7. Reducir exposición e impacto mediante segmentación, mantenimiento, protección de datos y respaldos.
8. Mejorar respuesta y recuperación con procedimientos, ejercicios, registros y medición.

Las metas y sus denominadores se especifican en el Anexo 9; no se presentan como resultados institucionales ya alcanzados.

V. Alcance

El alcance propuesto comprende personal docente y administrativo, estudiantes y usuarios externos autorizados; servidores, estaciones y dispositivos; redes y conectividad; aplicaciones, bases de datos, correo, nube y sistemas universitarios; y proveedores con acceso o responsabilidad sobre información. Incluye funciones de trámite documentario, tesorería, rentas o recaudación, recursos humanos, portal, cámaras y copias de seguridad. Las categorías no observadas públicamente se incorporan al levantamiento, no como equipos ya inventariados.

V.1. Caso conductor y límites

Se selecciona como caso funcional la **gestión de solicitudes y documentos académicos**: usuario solicitante, personal tramitador, autorización, consulta de estado y entrega de información. Se utiliza para analizar integridad, confidencialidad, autorización y trazabilidad. No se confunde este portal con una plataforma general de mesa de partes; el ROF atribuye funciones de trámite documentario a Secretaría General, lo cual no demuestra que ambas soluciones sean la misma [2].

La observación institucional se limitó a páginas públicas, sin autenticación, envío de formularios, escaneo, explotación ni pruebas de carga. Las pruebas operativas se ejecutaron exclusivamente en el laboratorio. El perfil actual institucional de controles, la segmentación real, los contratos y la continuidad deben validarse con documentación y responsables antes de desplegar el plan.

V.2. Base normativa y responsabilidades

Fuente	Exigencia relevante	Aplicación al plan
ROF UNA, arts. 70–71	OTI depende de Rectorado y gestiona sistemas, infraestructura, gobierno digital y telecomunicaciones; vela por la seguridad de información automatizada.	Coordinación técnica con propietarios de procesos; no asumir que OTI y OSCD sean el mismo rol.
DU 007-2020, arts. 7–9	Marco de Confianza Digital y reporte al CNSD; SGSI y CSIRT cuando corresponda.	Registrar y evaluar incidentes; formalizar responsabilidades y coordinación.
DS 126-2025-PCM, arts. 11 y 31–34	Coordinación a cargo de OSCD; notificación al CNSD. El art. 32.1 fija hasta 48 horas para incidentes críticos.	Triage inmediato; otros niveles según clasificación y plazos SGTD vigentes, no un plazo universal de 48 horas.
Ley 29733, arts. 9 y 16	Medidas técnicas, organizativas y legales frente a alteración, pérdida y tratamiento o acceso no autorizado a datos personales.	Clasificación, acceso por necesidad, trazabilidad, cifrado y respuesta.
DS 016-2024-JUS, art. 34	Aviso a ANPD hasta 48 horas en los supuestos del art. 34.1; deber distinto de comunicación al titular en 34.3 y coordinación digital en 34.5.	Evaluar volumen, sensibilidad y afectación de derechos. Una subsanación no elimina automáticamente el deber de notificar a ANPD.

Las referencias normativas completas y sus copias documentales se incluyen en la bibliografía [14, 15, 16, 17]. Los plazos de atención interna propuestos son más breves para permitir análisis y notificación dentro del plazo aplicable, sin sustituir el cómputo legal.

VI. Inventario y clasificación de activos

La unidad de inventario es el activo o servicio con un propietario identificable. Se registrarán identificador, finalidad, ubicación o proveedor, custodio, información tratada, dependencias, exposición, versión cuando corresponda, criticidad, estado de verificación y fecha. Una URL no equivale al inventario del servidor que la aloja.

El Anexo 1 contiene **20 registros de cobertura**: siete servicios o elementos documentados y trece categorías sujetas a levantamiento. Los seis servicios web se respaldan por el catálogo institucional; el correo se sustenta en una dirección institucional publicada, sin atribuir proveedor. El inventario físico y sus cantidades no están disponibles en esta investigación.

VI.1. Criterio de clasificación

La criticidad propuesta corresponde al mayor impacto en confidencialidad (C), integridad (I) y disponibilidad (D): 1 bajo, 2 medio, 3 alto y 4 crítico. Se evita promediar un impacto crítico con otros menores. Por ejemplo, una alteración de una constancia puede ser crítica aunque su contenido no sea secreto. Las valoraciones del Anexo 2 son de planificación y requieren validación con los propietarios; no describen incidentes sufridos.

VII. Análisis de amenazas mediante STRIDE

VII.1. Componentes, usuarios y límites de confianza

El modelo lógico contempla: solicitante, navegador, punto de entrada, servicio de identidad, aplicación, repositorio de datos, registro de auditoría, respaldo y personal autorizado. Las fronteras separan Internet del servicio, autenticación de autorización, aplicación de datos y operación de administración. Es una **arquitectura objetivo de análisis**, no un diagrama extraído de la infraestructura universitaria.

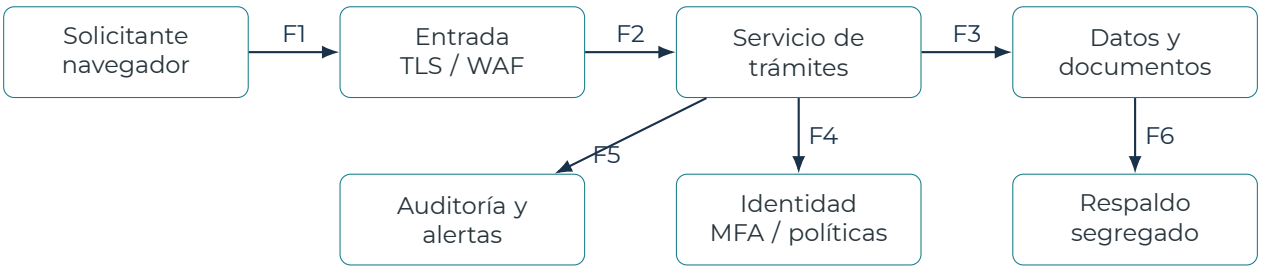


Figura 1: Modelo lógico propuesto: los flujos F1–F6 permiten analizar fronteras y controles.
Fuente: Elaboración analítica a partir del proceso público de trámites y STRIDE; no topología real de la UNA.

VII.2. Procedimiento y evaluación

Para cada flujo se identifica quién actúa, qué información cruza, qué propiedad puede perderse y qué condición permitiría el abuso. STRIDE incluye suplantación (S), manipulación (T), repudio (R), divulgación (I), denegación de servicio (D) y elevación de privilegios (E) [6]. El Anexo 3 registra doce escenarios y su relación con controles y pruebas.

Se usa riesgo $R = P \times I$, con probabilidad e impacto entre 1 y 4. Probabilidad: 1 requiere condiciones excepcionales; 2 acceso o precondiciones específicas; 3 exposición y oportunidad recurrente; 4 explotación conocida y exposición local corroborada. Impacto: 1 limitado; 2 afecta un área recuperable; 3 afecta un proceso relevante o datos sensibles; 4 afecta derechos, integridad académica o continuidad esencial. Nivel: 1–3 bajo, 4–6 medio, 7–11 alto, 12–16 crítico. Sin exposición corroborada no se asigna P4 por existir únicamente un aviso externo.

El riesgo inherente refleja el escenario antes del tratamiento. El residual del Anexo 3 es **objetivo condicionado a controles eficaces**, no riesgo institucional medido. El propietario acepta el residual o solicita más tratamiento. No se declara mitigado un escenario por tener una herramienta instalada: se exige prueba y revisión.

VIII. Inteligencia de amenazas

VIII.1. Ciclo de vigilancia

El proceso propuesto es: recopilar fuentes primarias; deduplicar y fechar; analizar conducta, producto y contexto; clasificar prioridad y confianza; crear indicadores con vigencia; comunicar al propietario; actualizar controles; y cerrar con una decisión de aplicabilidad. OTI realiza el análisis técnico; OSCD coordina el escalamiento; propietarios confirman productos, servicios y exposición.

Se vigilarán phishing, dominios similares al institucional, IP maliciosas, malware, ransomware, vulnerabilidades e incidentes documentados en entidades públicas. Los dominios sospechosos se identificarán por monitoreo pasivo autorizado y reportes de usuarios; no se afirma haber encontrado dominios falsos de la UNA. Los IOC se compararán con registros existentes de DNS, correo, proxy y EDR, previa validación de vigencia y posibles servicios compartidos.

VIII.2. Boletín TI-2026-01: corte al 18/10/2026

Aviso real	Hecho, causa y efecto	Decisión y acción propuesta
TI-01 · CISA, 16/10/2026	CVE-2026-102764: bypass de autenticación en BeyondTrust Remote Support hasta 26.2.3; explotación activa. CISA distingue instalaciones propias de SaaS ya parcheado.	Prioridad alta *si* inventario confirma producto/versión/modalidad. Validar en un día hábil; aplicar parche BT26-05-RS o actualizar según fabricante; preservar registros si se sospecha compromiso. Exposición UNA: V.

Aviso real	Hecho, causa y efecto	Decisión y acción propuesta
TI-02 · CISA AA26-222A, 10/08/2026	Gunra RaaS: cifrado y extorsión por publicación de datos. El aviso incluye academia como sector afectado; no identifica a la UNA.	Preparación alta: reducir servicios expuestos, segmentar y probar restauraciones aisladas. El cifrado no agota el riesgo: recuperar disponibilidad no elimina una posible fuga. Exposición UNA: V.
TI-03 · CISA AA26-281A, 08/10/2026	Actores combinan escaneo, XSS, robo de credenciales y exfiltración; el aviso documenta víctimas en educación y otros sectores.	Correlacionar con inventario y telemetría; endurecer entrada web, proteger identidad y revisar accesos. No atribuir phishing a conductas que el aviso describe como XSS. Exposición UNA: V.
TI-04 · FBI/CISA, 16/10/2026	Aviso de phishing/smishing dirigido a autoridades electorales de EE. UU.; describe robo de credenciales y uso de mensajes convincentes.	Patrón transferible a capacitación y protección del correo; no prueba campaña universitaria ni peruana. Promover verificación por segundo canal y MFA resistente a phishing.

Fuentes: TI-01 [19]; TI-02 [20]; TI-03 [18]; TI-04 [21]. La confianza es alta en lo que la fuente oficial documenta; la aplicabilidad local permanece por validar. Los avisos no autorizan bloqueo indiscriminado ni prueban infección.

VIII.3. Indicadores y comunicación

Tipo	Indicador y contexto	Tratamiento
Dominio	`dns[.]studiocloud[.]xyz`; citado por AA26-281A asociado a comunicaciones del ejecutable analizado.	Comparar con logs; fecha de primera/última observación no precisada en la ficha.
IPv4	`23.239.119[.]2`; aviso Gunra, observación de julio a 06/11/2025.	Histórico; no presumir control actual ni bloquear sin revisión.
CVE	CVE-2026-102764; condición de producto y modalidad identificada en TI-01.	Inventario y fabricante determinan aplicabilidad.

Los indicadores se presentan neutralizados y no se visitaron. Cada alerta conservará fuente, fecha, confianza, caducidad, propietario, decisión y evidencia. Una coincidencia inicia triage; no equivale por sí sola a compromiso. La comunicación urgente se dirige a OSCD y al dueño del servicio; el boletín periódico sintetiza acciones y cierres para Alta Dirección.

IX. Análisis con MITRE ATT&CK

ATT&CK caracteriza el comportamiento del adversario por tácticas y técnicas; las tácticas **no forman una secuencia rígida**. Este trabajo fija el catálogo Enterprise v20.0 para su matriz propia. Los avisos TI-02 y TI-03 conservan las versiones v19.1 y v19 indicadas por sus autores [8, 18, 20].

El Anexo 4 distingue tres conductas efectivamente ejecutadas con archivos ficticios (T1083, T1005 y T1074.001) de técnicas únicamente analizadas para el escenario. Una autenticación legítima no demuestra abuso de cuentas T1078; un intento fallido aislado no prueba fuerza bruta. Para detección se registran entradas necesarias, regla, criterio observable y respuesta. La ausencia de telemetría institucional es una brecha de evaluación, no una prueba de ausencia de controles.

X. Análisis mediante Cyber Kill Chain

La cadena de Lockheed Martin comprende reconocimiento, armamento, entrega, explotación, instalación, comando y control y acciones sobre el objetivo [7]. El caso analítico es una intrusión que busca documentos universitarios, apoyado en las conductas externas de TI-02/TI-03, sin atribuirla a la UNA.

El Anexo 5 asigna controles a las siete etapas. La ejecución local comprende únicamente descubrimiento, recopilación y staging de archivos, detección y restauración. No se ejecutaron phishing contra personas, explotación de servidores, malware, persistencia ni C2. Interrumpir una fase reduce oportunidades; no demuestra que todas las intrusiones sigan el mismo orden o requieran todas las etapas.

XI. Implementación de Zero Trust

La política es **nunca confiar automáticamente; verificar explícitamente**. La ubicación en la red no concede acceso. Toda decisión debe considerar sujeto, recurso, acción, dispositivo y contexto, con privilegio mínimo y reevaluación [4].

1. **Identidades:** cuentas individuales, verificación del alta, MFA para privilegios y acceso sensible; cuentas técnicas separadas con credenciales rotadas y alcance mínimo.
2. **Dispositivos:** inventario y enrolamiento, soporte vigente, cifrado y estado de protección antes de acceder a recursos críticos. Una cabecera enviada por el cliente no prueba postura del equipo.
3. **Datos:** clasificación por sensibilidad y proceso; autorización en servidor para cada objeto; protección de exportaciones y registros.
4. **Red:** separación de administración, usuarios, aplicaciones, bases y cámaras; reglas explícitas y acceso de proveedor temporal. Los segmentos reales deben levantarse con OTI.
5. **Ciclo de acceso:** aprobar altas/cambios; revisar privilegios trimestralmente y al cambio de función; suspender cuentas sin propietario o inactivas tras validación; revocar accesos al cese y cerrar sesiones activas.
6. **Observación:** correlacionar autenticación, autorización, fallos y cambios de privilegio; investigar anomalías y retirar acceso cuando el riesgo lo exija.

El laboratorio comprobó MFA, autorización y revocación; no validó postura de equipos ni microsegmentación de la universidad. El Anexo 6 contiene la matriz de roles, cuentas de prueba y permisos, y sus evidencias. TOTP se contrastó con un vector SHA-1 del apéndice B de RFC 6238 [22]; mejora frente a contraseña sola, pero no es MFA resistente a phishing ni constituye por sí mismo una arquitectura Zero Trust completa.

XII. Matriz NIST CSF 2.0 aplicada

La siguiente matriz es el perfil objetivo inicial. Los códigos corresponden a resultados CSF; las herramientas son opciones de implementación, no productos constatados en la UNA [3].

Función	Acción y resultado	Responsable propuesto	Control, herramienta y evidencia
Govern	GV.RR-02 / GV.RM-01: establecer autoridad, responsabilidades y tolerancia al riesgo; aprobar política y recursos.	Alta Dirección; OSCD; propietarios; OTI técnica.	RACI y registro de riesgos; actas, designaciones y decisiones de aceptación. Estado actual: V.

Función	Acción y resultado	Responsable propuesto	Control, herramienta y evidencia
Identify	ID.AM-01/02 / ID.RA-01: inventariar hardware y servicios; validar vulnerabilidades y dependencias.	OTI y propietarios; logística para asignación.	CMDB o inventario controlado; conciliación física/lógica y registro de vulnerabilidades. Base pública: Anexo 1.
Protect	PR.AA-03 / PR.PS-02 / PR.AT-01: autenticar, mantener software y capacitar.	OTI; responsables de identidad y sistemas; RR. HH.	IdP con MFA, gestión de parches, cifrado, formación. Prueba local: AUTH/RBAC/SESSION; despliegue institucional: V.
Detect	DE.CM-01 / DE.AE-02: monitorear y analizar eventos adversos.	Equipo técnico de monitoreo/CSIRT designado.	SIEM/EDR o registros centralizados; alertas correlacionadas y bitácora. LAB-DET-001 demuestra sólo regla local.
Respond	RS.MA-01 / RS.CO-02: ejecutar respuesta y notificar según clasificación.	OSCD/CSIRT; propietario; asesoría legal.	Tickets, playbooks y comunicaciones; tiempos, decisión de contención y evaluación de notificación.
Recover	RC.RP-01 / RC.CO-03: restaurar y comunicar progreso.	OTI; propietario; continuidad institucional.	Copias segregadas, pruebas y actas de aceptación. RECOVERY-01 verifica archivos; RTO/RPO institucionales por validar.

XIII. Controles de seguridad

La implementación se prioriza por riesgo y dependencia: primero conocer activos y accesos; luego reducir exposición y obtener telemetría; finalmente ampliar automatización y resiliencia. No se despliega un SIEM sin fuentes, responsables y reglas accionables.

ID	Control	Aplicación y criterio de eficacia	Prioridad / evidencia
C01	MFA e identidad	Accesos sensibles y privilegiados; preferir factores resistentes a phishing, recuperación de cuenta controlada.	P1; AUTH-01–03 en lab; cobertura institucional V.
C02	Autorización	Denegación por defecto, validación rol y objeto en servidor, separación de funciones.	P1; RBAC e IDOR locales.
C03	Auditoría	Actor, UTC, recurso, acción, resultado y correlación; envío a repositorio separado con acceso restringido.	P1; AUDIT-01. Inmutabilidad institucional P.
C04	Límite y validación	Tamaño y tipo de entrada; límites por usuario/ruta con umbrales ajustados al servicio.	P1; INPUT-01 no demuestra resistencia DDoS.
C05	Firewall y WAF	Publicar sólo servicios necesarios; políticas revisadas; WAF para rutas web según pruebas y falsos positivos.	P2; reglas y pruebas controladas institucionales P.
C06	EDR/antimalware	Protección de equipos y servidores compatibles, actualización y revisión de alertas.	P2; inventario de cobertura y prueba autorizada P.
C07	Cifrado	TLS para tránsito; cifrado de equipos, datos y copias según clasificación; claves separadas.	P1; certificados/configuración e inventario de claves V.
C08	SIEM/monitoreo	Centralizar identidad, aplicación, red y endpoint; casos de uso, turno y escalamiento definidos.	P2; alerta local E, SIEM institucional V.
C09	Segmentación	Administración separada de usuarios y cámaras; base accesible sólo por aplicaciones autorizadas.	P2; matriz de flujos y verificación de reglas P.

ID	Control	Aplicación y criterio de eficacia	Prioridad / evidencia
C10	Vulnerabilidades	Inventario/versiones, priorización KEV y exposición, prueba en entorno de cambios y seguimiento.	P1; plazos según criticidad, cierre con evidencia.
C11	Copias de seguridad	Copias segregadas y al menos una fuera de línea o inmutable; restauración de datos y validación funcional.	P1; RECOVERY-01 local, esquema real V.
C12	Políticas/terceros	Alta/baja, acceso remoto temporal, contratos, incidentes, conservación y protección de datos.	P1; documentos y revisiones firmadas P.

XIV. Gestión de incidentes

XIV.1. Roles y canal de reporte

Se propone un canal único de reporte gestionado por OTI/CSIRT y publicado en el portal institucional: formulario o mesa de ayuda con categoría de seguridad y alternativa telefónica interna. No se inventa una dirección de correo ni se afirma que ese canal esté habilitado. El reporte mínimo contiene contacto, servicio, momento de observación, descripción y evidencia sin contraseñas ni datos personales innecesarios.

El canal recibirá correos sospechosos, accesos no autorizados, malware, ransomware, fuga de información y pérdida de equipos. El equipo receptor conserva el mensaje o evidencia original y evita solicitar reenvíos que propaguen adjuntos. OSCD coordina la clasificación y notificaciones; el dueño del servicio decide prioridad operativa; asesoría legal y el responsable de datos evalúan obligaciones; comunicaciones institucionales gestiona mensajes autorizados.

XIV.2. Flujo operativo

Etapa	Acción y decisión	Salida verificable
Detección	Recibir reporte/alerta; abrir ID; registrar UTC, activo, fuente y custodio. Preservar evidencia y calcular hash cuando proceda.	Ticket y original preservado.
Análisis	Confirmar evento, alcance, datos y dependencia; distinguir falso positivo e incidente; clasificar y activar responsables.	Línea de tiempo, alcance y severidad sustentados.
Contención	Revocar sesiones/cuentas implicadas; aislar equipo o ruta necesaria; preservar registros antes de cambios.	Decisión autorizada, efectos y servicio alterno.
Erradicación	Eliminar causa: cuenta, configuración, binario o vulnerabilidad; rotar secretos afectados y revisar persistencia.	Evidencia de corrección y reevaluación.
Recuperación	Restaurar desde copia íntegra, comprobar datos y función con propietario, vigilar recurrencia y reabrir gradualmente.	Hashes, prueba funcional y aceptación.
Evaluación posterior	Analizar causa y brechas, eficacia de respuesta y comunicación; asignar acciones con vencimiento.	Informe de cierre y mejora del plan.

El flujo operacional conserva las etapas de la consigna y se integra con la preparación y mejora continua del NIST SP 800-61 Rev. 3 [5]. La recuperación no debe destruir evidencia útil ni restablecer la misma condición insegura.

XIV.3. Clasificación, escalamiento y notificación

Crítico: afectación amplia de servicio esencial, integridad académica, propagación o exposición grave; activar coordinación inmediatamente. **Alto:** cuenta privilegiada o proceso relevante com-

prometido; **medio:** incidente acotado sin propagación; **bajo:** evento de impacto limitado. Son criterios internos propuestos, subordinados a la clasificación SGTD aplicable.

Como metas internas: confirmar recepción en 30 minutos para reportes críticos en ventana cubierta; iniciar análisis en una hora; documentar decisión de contención en dos horas; emitir seguimiento mientras persista impacto. La cobertura fuera de horario exige guardia o proveedor formal, no una promesa sin recursos. Estas metas no son tiempos medidos de la UNA.

La notificación al CNSD se evalúa desde el conocimiento del incidente: hasta 48 horas para críticos conforme al art. 32.1 del DS 126-2025-PCM; otros niveles según clasificación vigente. Si concurren los supuestos de datos personales del art. 34.1 del DS 016-2024-JUS, se notifica a ANPD dentro de 48 horas; se evalúan por separado comunicación al titular y notificación digital al CNSD. El registro consignará fundamento, momento de conocimiento, destinatario, fecha y actualizaciones [15, 17].

XIV.4. Respuestas por escenario

- **Phishing/cuenta comprometida:** preservar mensaje, revisar accesos y reglas de correo, revocar sesiones, restablecer credenciales por canal seguro y revisar otros recursos accesibles.
- **Ransomware:** aislar segmentos afectados, suspender propagación y preservar evidencias; comprobar alcance de exfiltración además del cifrado; restaurar desde copia verificada tras erradicación.
- **Fuga de información:** cerrar la ruta de exposición, identificar datos y personas afectadas, preservar accesos y evaluar obligaciones de comunicación.
- **Pérdida de equipo:** suspender sesiones y accesos, evaluar cifrado y datos locales; borrado remoto sólo si existe capacidad autorizada y sin sustituir la conservación que proceda.

XV. Capacitación y concientización

Se propone formación por rol, con ejercicios breves y evaluación práctica: personal general aprende a reconocer y reportar; tramitadores aplican clasificación y verificación; administradores practican privilegios, parches, registros y recuperación. El Anexo 10 integra phishing, ingeniería social, contraseñas, MFA, datos personales, correo, navegación, USB y reporte.

Las simulaciones de phishing del programa anual requieren autorización institucional, alcance y mensajes definidos, sin recolectar contraseñas reales ni publicar rankings individuales. Medirán entrega, reporte y conductas de riesgo, acompañadas de formación. No se ejecutó una campaña sobre usuarios universitarios en este trabajo: las pruebas realizadas corresponden a mecanismos técnicos locales.

XVI. Indicadores de cumplimiento

Cada indicador distingue actividad de resultado. Contar vulnerabilidades no mide seguridad sin conocer activos evaluados, criticidad y cierre. Los indicadores del Anexo 9 especifican fórmula, denominador, fuente, meta y responsable. Si el denominador es desconocido se registra *no disponible*; si es cero se registra *no aplica*, no un 100 % ficticio.

La medición de laboratorio produjo 13/13 casos funcionales conformes, 4/4 flujos de navegador conformes, una alerta sobre dos archivos preparados y 2/2 archivos con restauración íntegra. Estos valores no son porcentajes de cumplimiento institucional. No se calculan MTTD ni MTTR de la UNA, porque no se dispone de una serie de incidentes con marcas de tiempo comparables.

Conclusiones

1. La universidad dispone de servicios públicos identificables y competencias OTI documentadas. La aprobación, inventario interno, controles actuales y responsables especializados necesitan validación institucional para convertir esta propuesta en un plan operativo aprobado.
2. La integración de marcos evita controles aislados: las amenazas se relacionan con datos y decisiones de acceso; los comportamientos adversarios con telemetría; y los resultados con evidencia e indicadores.
3. Las ejecuciones reales demostraron mecanismos de autenticación, autorización, auditoría, revocación, límites, detección local y restauración. Los 17 resultados conformes se circunscriben a casos definidos y no certifican la seguridad de la universidad ni de una aplicación productiva.
4. La restauración verificó una alteración controlada y restitución de archivos; no midió continuidad de un sistema completo. Del mismo modo, una solicitud limitada no acredita defensa DDoS y una regla local no equivale a un SIEM.
5. La implementación debe comenzar por propiedad de activos y riesgos, identidad privilegiada, telemetría y copias verificadas. El cronograma y la revisión trimestral permiten ajustar prioridades con hechos, no con supuestos.

Anexo 1. Inventario de activos y evidencia institucional

El inventario base cubre servicios documentados y categorías del alcance. **D** identifica elementos publicados; **V** categorías cuya existencia concreta, cantidades, ubicación y custodio deben levantarse. El propietario indicado es una asignación funcional propuesta, no una designación comprobada. Los datos C/I/D representan necesidades de protección propuestas (Anexo 2).

ID	Activo / categoría	Función y dependencia	Propietario propuesto	Estado
A01	Portal institucional	Información pública y acceso al catálogo; dependencia de alojamiento/DNS por validar.	Unidad de comunicación; OTI custodia técnica.	D, WEB01
A02	Campus Virtual	Catálogo de módulos académicos; matrícula/notas publicados.	Gestión académica; OTI.	D, WEB02
A03	Trámites académicos	Solicitudes de títulos, grados y constancias; seguimiento y entrega.	Registro y Archivo Académico; OTI.	D, WEB03
A04	Aula Virtual	Servicio enlazado en portal; funcionamiento autenticado no probado.	Gestión académica; OTI.	D; WEB04 sin imagen
A05	Repositorio institucional	Difusión de producción académica, enlace publicado.	Unidad responsable del repositorio; OTI.	D, WEB06
A06	Biblioteca digital	Consulta bibliográfica publicada en portal institucional.	Biblioteca; OTI.	D, R01
A07	Correo institucional	Dirección con dominio institucional publicada; plataforma y cantidad no verificadas.	Propietarios de cuentas; OTI.	D, R01
A08	Servidores	Cómputo de aplicaciones; cantidad, SO, versiones y ubicación desconocidos.	OTI.	V
A09	Estaciones/equipos	Trabajo docente/administrativo; asignación y cifrado por levantar.	Unidades usuarias; OTI.	V
A10	Bases de datos	Persistencia de información; motor, esquema, respaldos y permisos por validar.	Dueño de información; OTI.	V
A11	Redes y conectividad	Conmutación, enrutamiento, Wi-Fi y perímetro; topología desconocida.	OTI.	V
A12	Tesorería	Operaciones y documentos financieros; plataforma no constatada.	Unidad de tesorería; OTI.	V
A13	Rentas/recaudación	Registro de conceptos, cobros y conciliación; integración por validar.	Unidad de recaudación; OTI.	V
A14	Recursos humanos	Datos laborales y accesos vinculados al ciclo del personal.	RR. HH.; OTI.	V
A15	Trámite documentario general	Recepción/derivación documental; no equiparado a A03.	Secretaría General; OTI.	V; función en R02
A16	Cámaras y grabadores	Videovigilancia; dispositivos, retención y red por levantar.	Seguridad institucional; OTI.	V
A17	Copias de seguridad	Recuperación de sistemas/datos; medio, cifrado y pruebas desconocidos.	OTI y dueños de servicios.	V
A18	Servicios en nube	Contratos, regiones, identidades y responsabilidades compartidas.	Contratante; propietario; OTI.	V

ID	Activo / categoría	Función y dependencia	Propietario propuesto	Estado
A19	Proveedores tecnológicos	Acceso de terceros, soporte, subencargados y SLA.	Área contratante; OTI.	V
A20	Identidades y cuentas	Altas, bajas, permisos, cuentas técnicas y privilegiadas.	Propietarios; RR. HH.; OTI.	V

Levantamiento propuesto: conciliar adquisición/asignación, observación autorizada y dueño de servicio; registrar cantidad e identificador físico/lógico; identificar flujo de datos y proveedor; confirmar criticidad; y aprobar cambios. La cobertura se mide contra una línea base conciliada, no contra los veinte renglones de este catálogo.

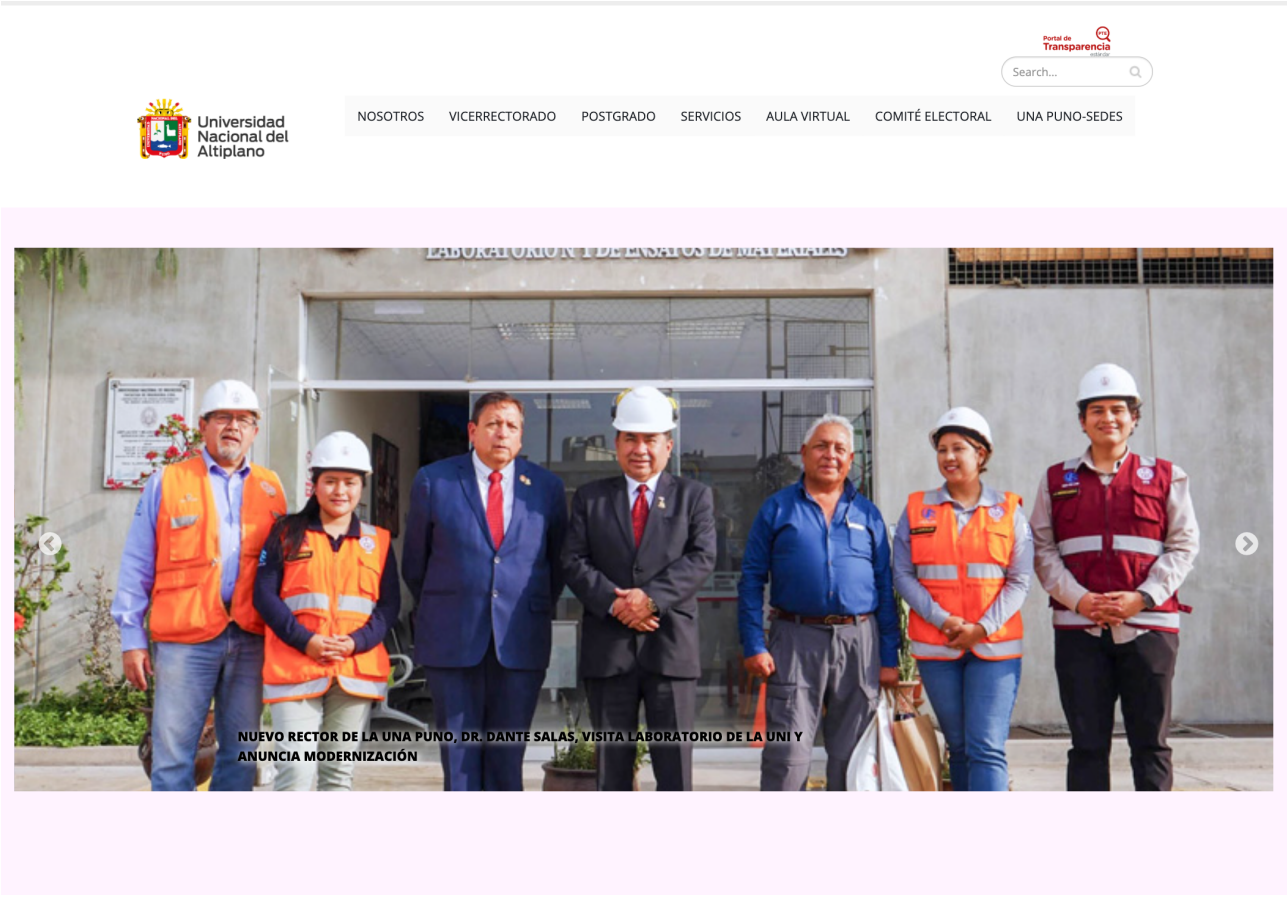


Figura 2: WEB01. Portal público de la UNA Puno.

Fuente: Captura directa de `https://portal.unap.edu.pe/`, 18/10/2026 (Perú), HTTP 200. Se bloquearon marcos externos de video; no se inició sesión.

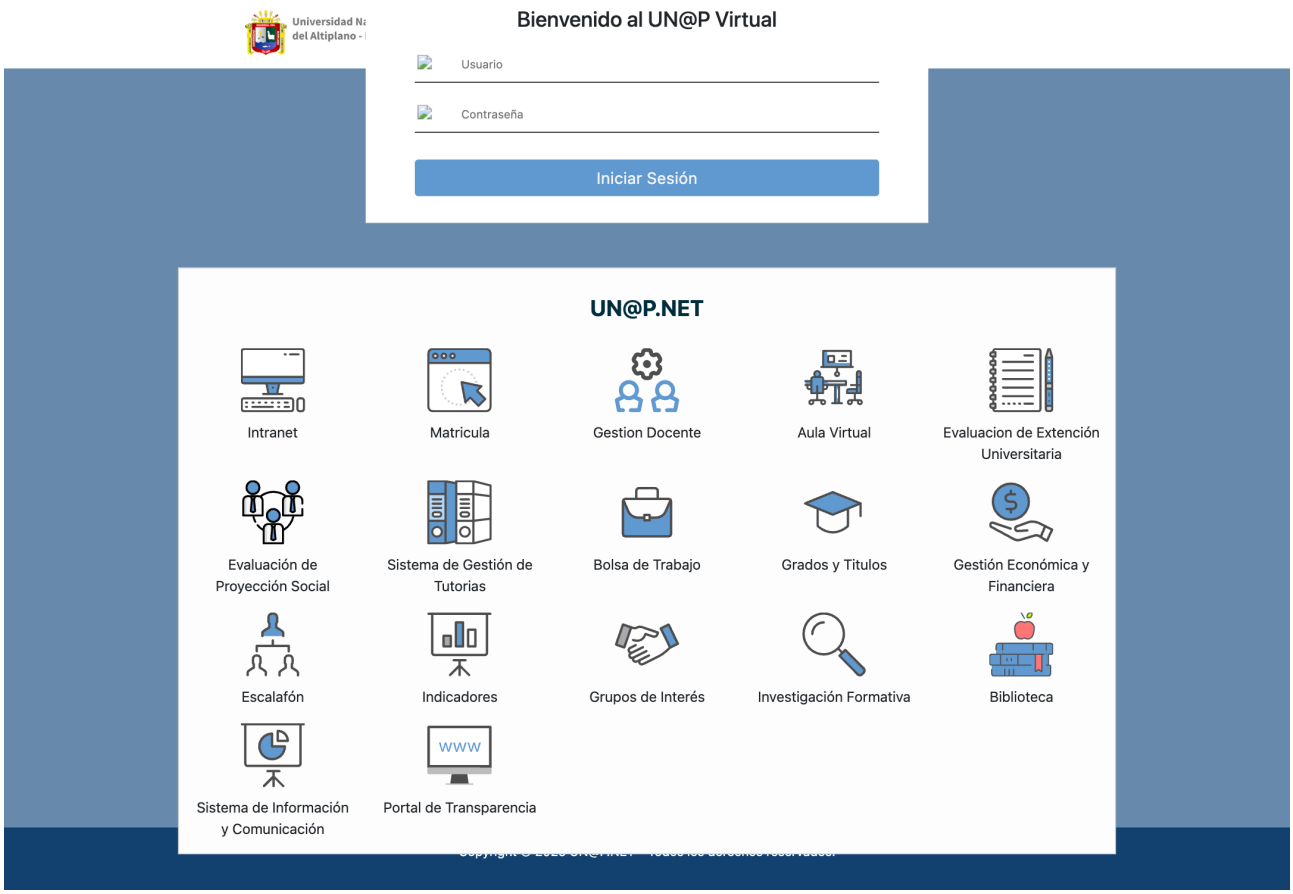
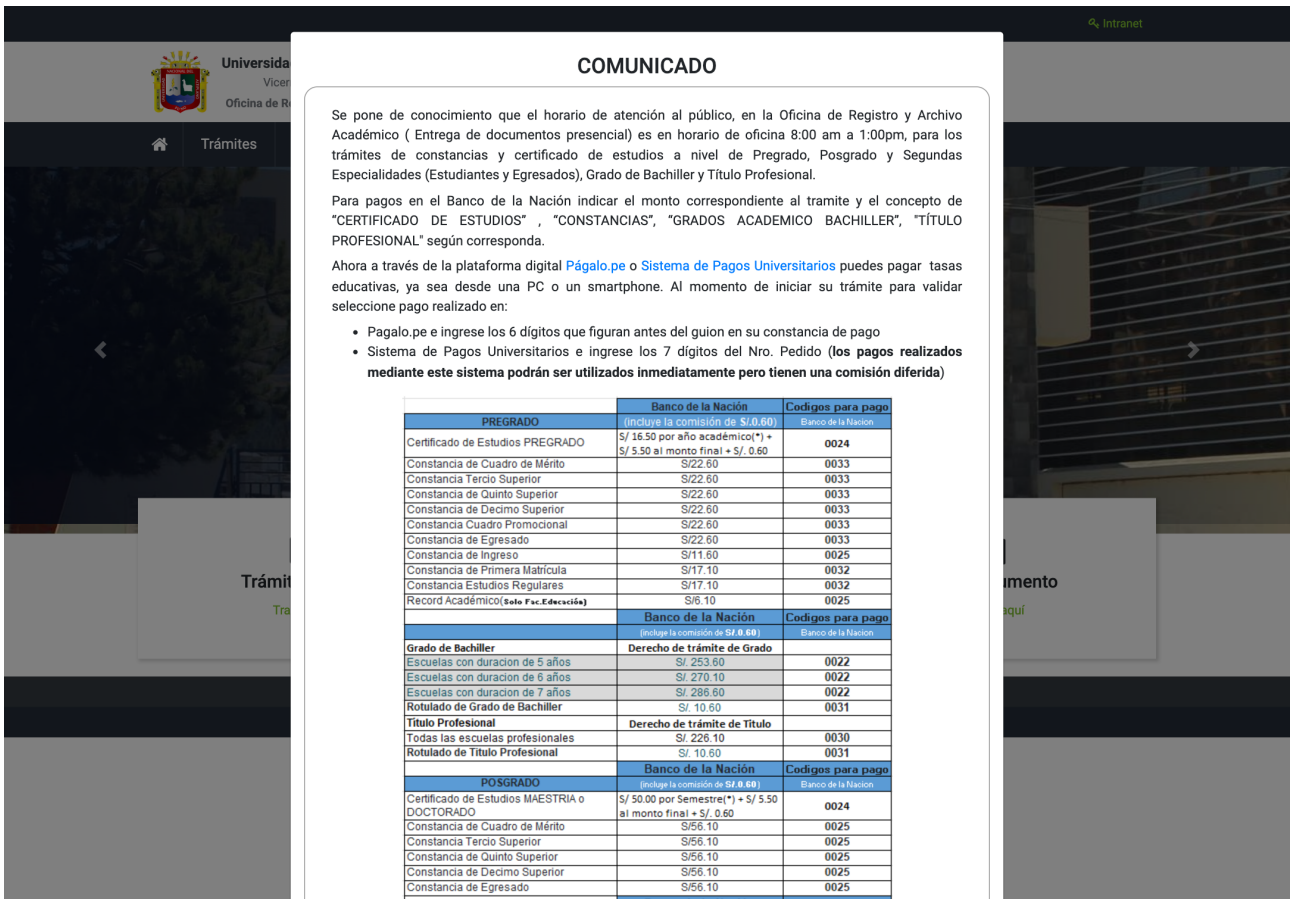


Figura 3: WEB02. Campus Virtual y catálogo público de módulos.

Fuente: Captura directa de `https://campus.unap.edu.pe/`, 18/10/2026, HTTP 200. No acredita operación de módulos autenticados.



COMUNICADO

Se pone de conocimiento que el horario de atención al público, en la Oficina de Registro y Archivo Académico (Entrega de documentos presencial) es en horario de oficina 8:00 am a 1:00pm, para los trámites de constancias y certificado de estudios a nivel de Pregrado, Posgrado y Segundas Especialidades (Estudiantes y Egresados), Grado de Bachiller y Título Profesional.

Para pagos en el Banco de la Nación indicar el monto correspondiente al tramite y el concepto de "CERTIFICADO DE ESTUDIOS" , "CONSTANCIAS", "GRADOS ACADEMICO BACHILLER", "TÍTULO PROFESIONAL" según corresponda.

Ahora a través de la plataforma digital Págalo.pe o Sistema de Pagos Universitarios puedes pagar tasas educativas, ya sea desde una PC o un smartphone. Al momento de iniciar su trámite para validar seleccione pago realizado en:

- Pagalo.pe e ingrese los 6 dígitos que figuran antes del guion en su constancia de pago
- Sistema de Pagos Universitarios e ingrese los 7 dígitos del Nro. Pedido (**los pagos realizados mediante este sistema podrán ser utilizados inmediatamente pero tienen una comisión diferida**)

	Banco de la Nación	Codigos para pago
PREGRADO	(incluye la comisión de S/.0.60)	Banco de la Nacion
Certificado de Estudios PREGRADO	S/ 16.50 por año académico(*) + S/ 5.50 al monto final + S/. 0.60	**0024**
Constancia de Cuadro de Mérito	S/22.60	**0033**
Constancia Tercio Superior	S/22.60	**0033**
Constancia de Quinto Superior	S/22.60	**0033**
Constancia de Decimo Superior	S/22.60	**0033**
Constancia Cuadro Promocional	S/22.60	**0033**
Constancia de Egresado	S/22.60	**0033**
Constancia de Ingreso	S/11.60	**0025**
Constancia de Primera Matrícula	S/17.10	**0032**
Constancia Estudios Regulares	S/17.10	**0032**
Record Académico(**Solo Fac.Educación**)	S/6.10	**0025**
	Banco de la Nación	**Codigos para pago**
	(incluye la comisión de **S/.0.60**)	Banco de la Nacion
Grado de Bachiller	**Derecho de trámite de Grado**	
Escuelas con duracion de 5 años	S/. 253.60	**0022**
Escuelas con duracion de 6 años	S/. 270.10	**0022**
Escuelas con duracion de 7 años	S/. 286.60	**0022**
Rotulado de Grado de Bachiller	S/. 10.60	**0031**
Título Profesional	**Derecho de trámite de Título**	
Todas las escuelas profesionales	S/. 226.10	**0030**
Rotulado de Título Profesional	S/. 10.60	**0031**
	Banco de la Nación	**Codigos para pago**
POSGRADO	(incluye la comisión de **S/.0.60**)	Banco de la Nacion
Certificado de Estudios MAESTRIA o DOCTORADO	S/ 50.00 por Semestre(*) + S/ 5.50 al monto final + S/. 0.60	**0024**
Constancia de Cuadro de Mérito	S/56.10	**0025**
Constancia Tercio Superior	S/56.10	**0025**
Constancia de Quinto Superior	S/56.10	**0025**
Constancia de Decimo Superior	S/56.10	**0025**
Constancia de Egresado	S/56.10	**0025**

Figura 4: WEB03. Portal de trámites: comunicado público y contexto del proceso académico.

Fuente: Captura directa de `https://tramites.unap.edu.pe/`, 18/10/2026, HTTP 200. Se conservó el comunicado tal como apareció.

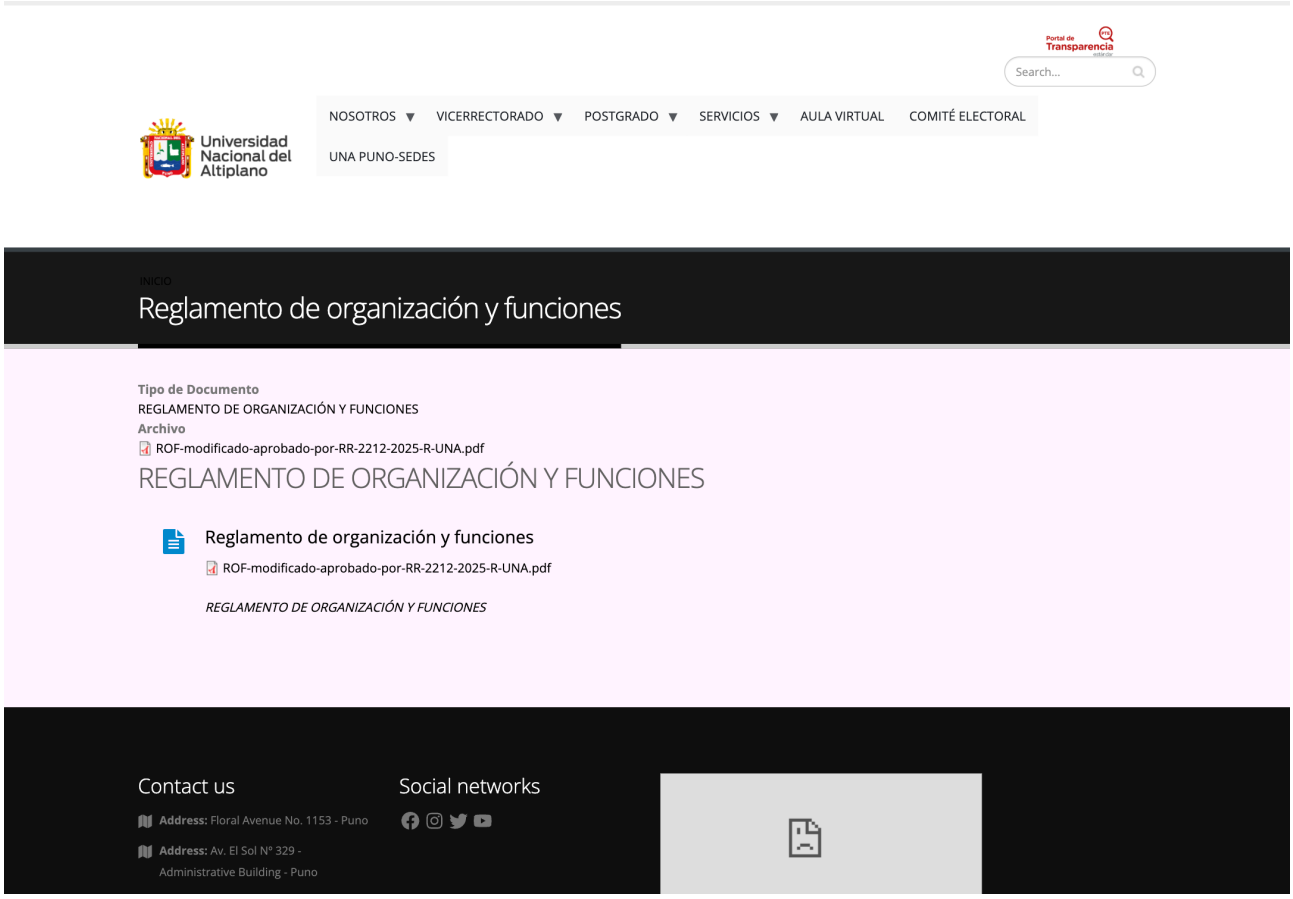


Figura 5: WEB05. Página institucional que publica el ROF.

Fuente: Captura directa de la página de reglamento; el análisis de funciones usa el PDF R02, no sólo esta imagen.

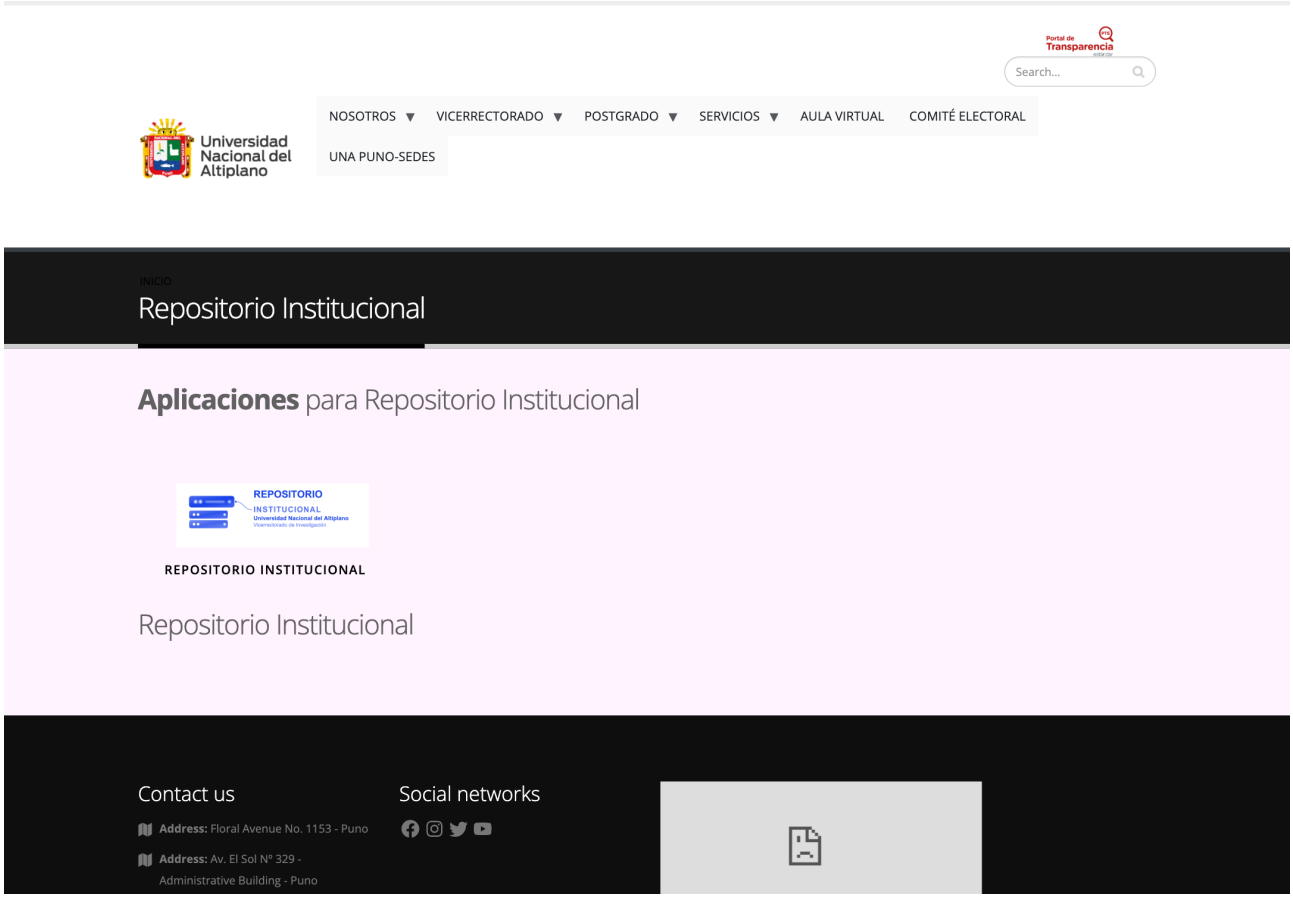


Figura 6: WEB06. Página pública del repositorio institucional.

Fuente: Captura de `https://portal.unap.edu.pe/repositorio-institucional`, 18/10/2026, HTTP 200. No valida contenido, autenticación ni alojamiento del repositorio enlazado.

Incidencia de observación WEB04: la URL de Aula Virtual devolvió HTTP 502 en dos intentos de la corrida de captura. Se conservó el estado en `evidencias/web/indice_web.json`; no se fabricó una imagen ni se atribuyó la causa. Es una observación puntual desde este entorno, no prueba de caída sostenida o vulnerabilidad.

Anexo 2. Matriz de criticidad

Nivel	Criterio de impacto	Respuesta propuesta
1 · Bajo	Información pública de impacto limitado y recuperación sencilla.	Gestión estándar y revisión anual.
2 · Medio	Afectación local, sin comprometer derechos ni servicio esencial.	Dueño asignado; revisión semestral.
3 · Alto	Afectación importante de proceso/unidad o datos de acceso restringido.	Revisión trimestral, accesos reforzados y prueba de recuperación.
4 · Crítico	Integridad académica/financiera, datos especialmente sensibles o continuidad esencial.	Tratamiento prioritario, acceso privilegiado controlado y pruebas documentadas.

Activo	C / I / D	Criticidad	Justificación funcional propuesta
A01	1 / 3 / 3	Alto	Información pública: alteración o indisponibilidad afecta confianza y acceso.
A02–A03	4 / 4 / 4	Crítico	Notas y documentos académicos requieren confidencialidad por rol e integridad verificable.
A04	3 / 3 / 3	Alto	Continuidad del proceso formativo y protección de información de usuarios.
A05	1 / 3 / 3	Alto	Publicación académica con necesidad de integridad y acceso persistente.
A06	2 / 2 / 2	Medio	Servicio bibliográfico; elevar si integra datos o dependencias críticas.
A07, A20	4 / 4 / 3	Crítico	Una identidad puede habilitar acceso transversal; permisos y recuperación de cuenta son determinantes.
A08, A10	4 / 4 / 4	Crítico	Clase de soporte de datos y servicios; validar por instancia y no asignar criticidad a todos sin análisis.
A09	3 / 3 / 2	Alto	Riesgo condicionado a datos locales, usuario y acceso; elevar estaciones privilegiadas.
A11	3 / 4 / 4	Crítico	Puede ser dependencia común; segmentación y redundancia por validar.
A12–A14	4 / 4 / 3	Crítico	Procesos financieros/laborales con datos personales e integridad de transacciones.
A15	3 / 4 / 3	Crítico	Trazabilidad y autenticidad de documentos; confirmar sensibilidad por expediente.
A16	3 / 3 / 2	Alto	Imágenes de personas y acceso administrativo; validar retención y cobertura.
A17	4 / 4 / 4	Crítico	Copias concentran datos y condicionan recuperación; proteger contra modificación y borrado.
A18–A19	Según servicio	Heredada	El tercero o nube hereda impacto del dato/servicio y añade dependencias contractuales.

Las puntuaciones son una propuesta inicial de protección, no mediciones de pérdida ni clasificación aprobada de cada activo físico.

Anexo 3. Matriz STRIDE y pruebas desarrolladas

ID/tipo	Activo / flujo	Amenaza, condición y efecto	Riesgo P×I	Tratamiento y residual objetivo	Prueba / estado
S01 / S	A03,A20 / F1,F4	Suplantar identidad con credencial ajena; si autenticación no exige segundo factor, acceso a documentos. Condición institucional V.	3×4=12 crítico	C01 MFA y recuperación segura; residual 2×4=8 alto, porque persiste phishing de sesión.	AUTH-01–03 E; C01 institucional P.
S02 / S	A07 / F1	Mensaje que suplanta autoridad o dominio; usuario entrega secreto o autoriza pago. No se halló campaña UNA.	3×4=12 crítico	Verificación por segundo canal, protección de correo, formación; 2×4=8 alto.	TI-04 documental; campaña P.
S03 / T	A03,A10 / F3	Lector modifica contenido por fallo de autorización; altera integridad de constancia.	3×4=12 crítico	C02 validar rol/objeto y conservar historial; 1×4=4 medio.	INT-01 403 sin cambio E.
S04 / T	A17 / F6	Alteración de copia accesible desde cuenta operativa; pérdida de restaurabilidad.	2×4=8 alto	C11 copias segregadas/inmutables y verificación; 1×4=4 medio.	RECOVERY-01 E en archivos; segregación UNA V.
S05 / R	A03 / F5	Acción sin actor o correlación; no puede reconstruirse una modificación o rechazo.	3×3=9 alto	C03 campos y envío a repositorio independiente; 1×3=3 bajo.	AUDIT-01 E; inmutabilidad no demostrada.
S06 / R	A19,A20 / F4,F5	Cuenta compartida de proveedor impide atribución individual.	2×3=6 medio	C12 cuentas nominales, ventana y revisión; 1×3=3 bajo.	Verificación contractual P.
S07 / I	A03,A10 / F3	Cambiar identificador permite leer un documento ajeno si falta autorización por objeto.	3×4=12 crítico	C02 control servidor y respuesta genérica; 1×4=4 medio.	IDOR-01: A=200, B=404 E.
S08 / I	A07,A17 / F3,F6	Exportar datos o copias con privilegio excesivo y sin monitoreo.	2×4=8 alto	C07,C08,C11 mínimo acceso, cifrado y observación; 1×4=4 medio.	ATTACK-01 E sólo fixtures; cifrado P.
S09 / D	A03 / F1,F2	Entrada sobredimensionada consume recursos si no hay límites.	3×3=9 alto	C04 límites por ruta/cuenta y monitoreo; 2×3=6 medio.	INPUT-01 413; posterior 201 E.
S10 / D	A08,A11 / F2	Interrupción de una dependencia común sin alternativa validada.	2×4=8 alto	C05,C09,C11 continuidad y pruebas; 1×4=4 medio.	Restauración parcial E; continuidad P.
S11 / E	A03,A20 / F2,F4	Usuario básico invoca función administrativa si sólo se oculta botón en UI.	3×4=12 crítico	C02 denegación por defecto en servidor; 1×4=4 medio.	RBAC-01/02: 403/200 E.
S12 / E	A20 / F4	Cuenta retirada conserva sesión y privilegios; acceso persiste tras revocación administrativa.	2×4=8 alto	C01,C02 revocar tokens/sesiones y revisar cuentas; 1×4=4 medio.	SESSION-01: 200 revocar, 401 reutilizar E.

Procedimientos, resultados y causalidad

Las precondiciones son servicio local en ejecución, fixtures separados por usuario y cuentas de prueba con roles conocidos. Cada caso verifica el código HTTP y el estado del recurso, no sólo el texto de la pantalla. La denegación prevista se considera resultado conforme: un HTTP 403 en RBAC-01 demuestra el bloqueo esperado, no un fallo de la prueba.

Caso	Paso y resultado observado	Interpretación
AUTH-01/02/03	Credencial inválida: 401; contraseña sin TOTP: 401; TOTP válido: sesión lector.	El segundo factor condiciona concesión, no sólo decoración de interfaz.
INT-01 / RBAC-03	Lector: actualización 403 y contenido igual; editor: modificación propia 200.	Se diferencian prohibición y operación legítima; no bloqueo indiscriminado.
AUDIT-01	Evento con actor, UTC, acción, resultado y request_id coincidente.	Permite correlación del rechazo probado; no demuestra atribución de todas las acciones ni no repudio legal.
IDOR-01	Registro propio A: 200; ajeno B: 404 sin contenido.	Verificación por recurso evita divulgación horizontal.
INPUT-01	65 537 bytes: 413 con límite 65 536; 73 bytes posteriores: 201.	Límite funciona en una solicitud; no se midió saturación concurrente.
RBAC-01/02	Lector: 403 a administración; administrador: 200.	La política se aplica por rol en servidor.
SESSION-01	Revocación 200; reutilización del valor anterior: 401.	La sesión deja de autorizar; no se presume sólo cierre visual.

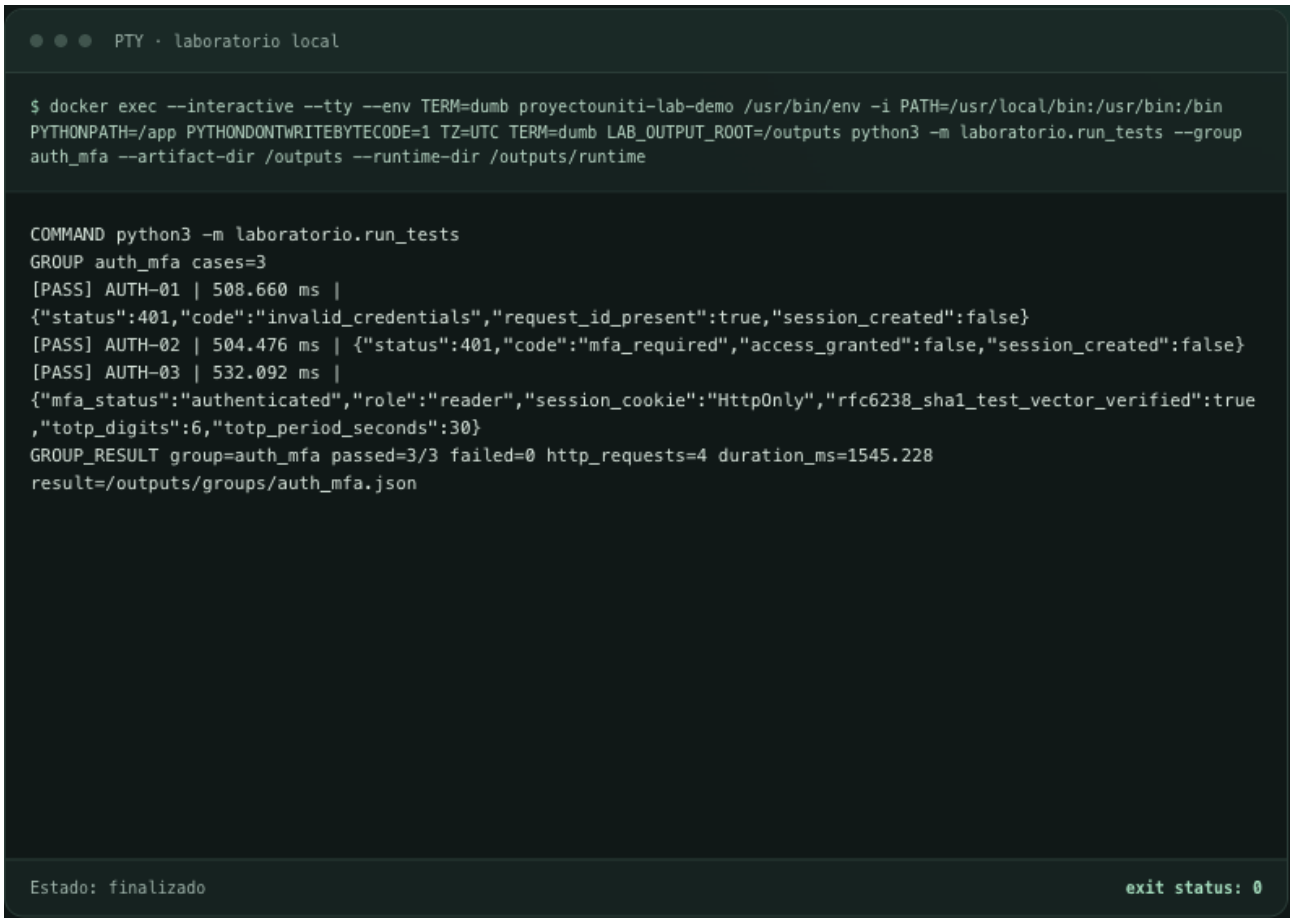


Figura 7: TERM-01. Ejecución PTY de autenticación y MFA, con terminación 0.

Fuente: Recorte geométrico del PNG original; proceso real `run_tests--groupauth_mfa`. Original y log conservados.

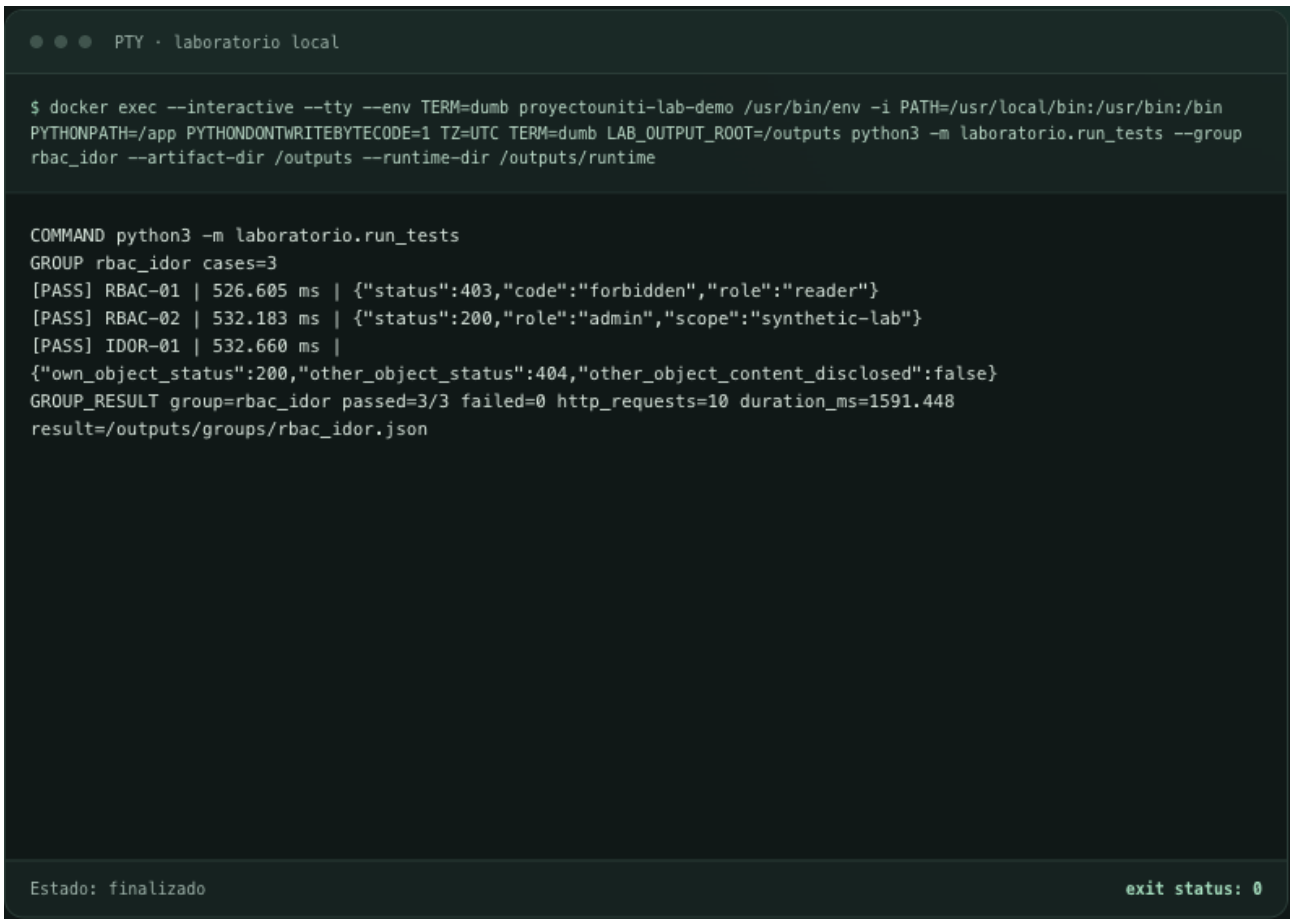


Figura 8: TERM-02. Autorización por rol y objeto: rechazo lector, acceso administrador y aislamiento A/B.

Fuente: Detalle sin edición de texto de la consola PTY; grupo `rbac_idor`.

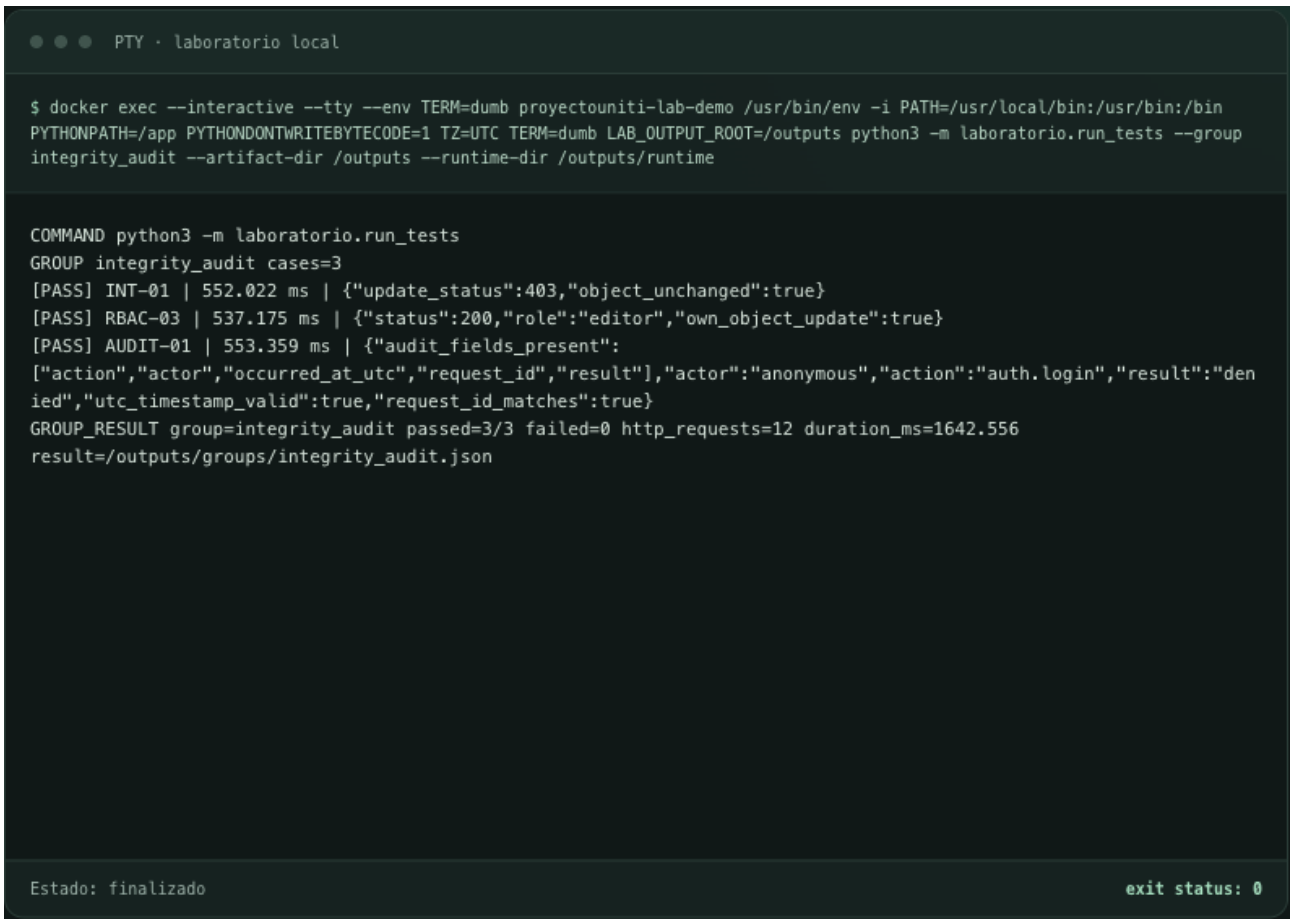


Figura 9: TERM-03. Integridad y campos de auditoría contrastados por las pruebas.

Fuente: Detalle de captura original; grupo `integrity_audit`. La prueba de auditoría inspecciona el evento concreto descrito.

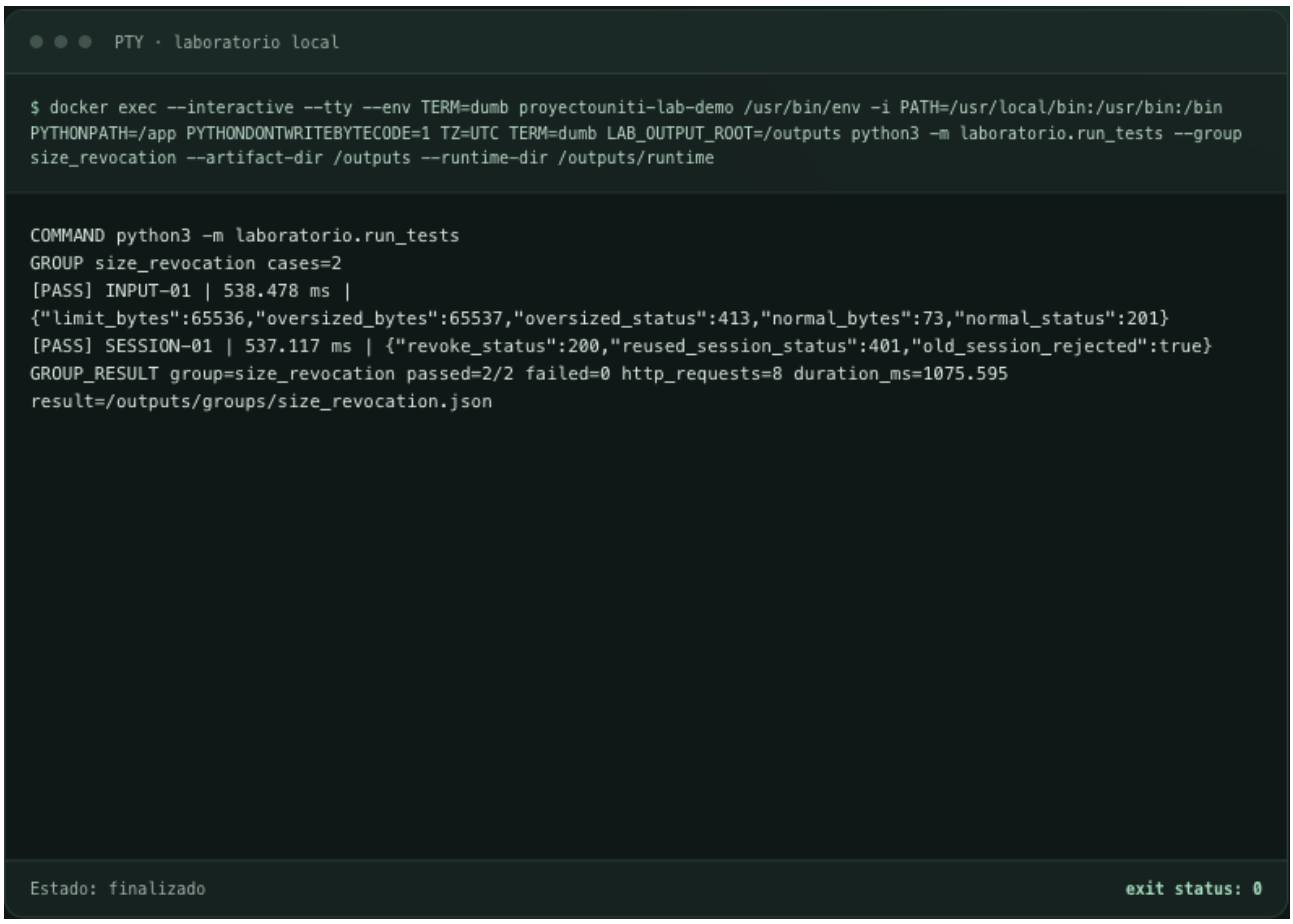


Figura 10: TERM-04. Solicitud limitada y sesión revocada: rechazo esperado y servicio posterior operativo.

Fuente: Detalle de captura PTY; grupo `size_revocation`. No se ejecutó un ataque de carga.

Anexo 4. Matriz MITRE ATT&CK y evidencia de ejecución

Táctica / técnica	Comportamiento	Detección y respuesta propuesta	Evidencia / alcance
Reconocimiento / T1595.002	Escaneo de vulnerabilidades descrito por TI-03.	Correlacionar recorridos y fallos; revisar exposición, no bloquear sólo por un evento.	Documental R18; no ejecutado en UNA ni lab.
Acceso inicial / T1566	Phishing, según taxonomía MITRE y TI-04.	Reportes, correo y accesos; preservar mensaje y revocar sesión comprometida.	R13/R21; no campaña local ejecutada.
Acceso / T1078	Abuso de cuentas válidas.	Contexto de autenticación, cambios y recurso; investigar y suspender acceso.	R12; AUTH legítimo no se etiqueta como abuso ejecutado.
Ejecución / T1059.006	Python usado por actores en TI-03.	Proceso, padre, ruta y contexto; restringir ejecución no autorizada.	R18; usar Python en pruebas no reproduce por sí solo esta TTP.
Persistencia / T1133	Servicios remotos descritos en TI-03.	Inventario de agentes/VPN y conexiones; retirar acceso no aprobado.	R18; sólo analizado.
Escalada / T1068	Explotación para elevar privilegios como riesgo a evaluar [24].	Versión, parche y eventos; aislar y corregir si se confirma.	Escenario, sin explotación ni vulnerabilidad local afirmada.
Descubrimiento / T1083	Enumerar exclusivamente dos archivos incluidos en fixture.	Inventario observado y rutas acotadas; revisar contexto y permisos.	ATTACK-01 E; [9].
Recopilación / T1005	Leer y copiar los archivos ficticios del directorio local.	Registro de acceso/exportación y permisos; limitar alcance.	ATTACK-01 E; [10].
Recopilación / T1074.001	Reunir copias en directorio local de staging.	LAB-DET-001 observa archivos y genera alerta; analista valida y contiene.	ATTACK-01 E; [11].
Movimiento lateral / T1021	Uso indebido de servicios remotos para alcanzar otro host [25].	Identidad/red/origen y destino; segmentar y revocar acceso.	Escenario de planificación; no ejecutado.
Exfiltración / T1020	Transferencia automatizada descrita en TI-03.	Volumen/destino, registros proxy y aplicación; cortar ruta y evaluar datos.	R18; staging no prueba exfiltración.

Regla local LAB-DET-001

El procedimiento enumera los dos fixtures, copia sus bytes a `staging` y ejecuta una función separada que observa archivos regulares en ese directorio. La condición *existe al menos un archivo* genera un evento con ID, regla, UTC, clasificación y cantidad. El resultado observado fue dos archivos y una alerta. Es una regla autocontenida del laboratorio, no un sensor independiente, despliegue SIEM/EDR ni evidencia de exfiltración.

```
rule_id: LAB-DET-001
scope: laboratory/runtime/attack_fixture/staging
condition: observed_regular_file_count > 0
action: emit LAB-ALERT-001 to alerts.jsonl
triage: validate actor, source, authorization and affected files
```

La ruta operativa exacta del archivo se conserva en el directorio de evidencia; el bloque expresa la lógica de la regla. En producción se requieren eventos de archivo/proceso o exportación independientes, umbral, excepciones, responsable de atención y verificación de falsos positivos.

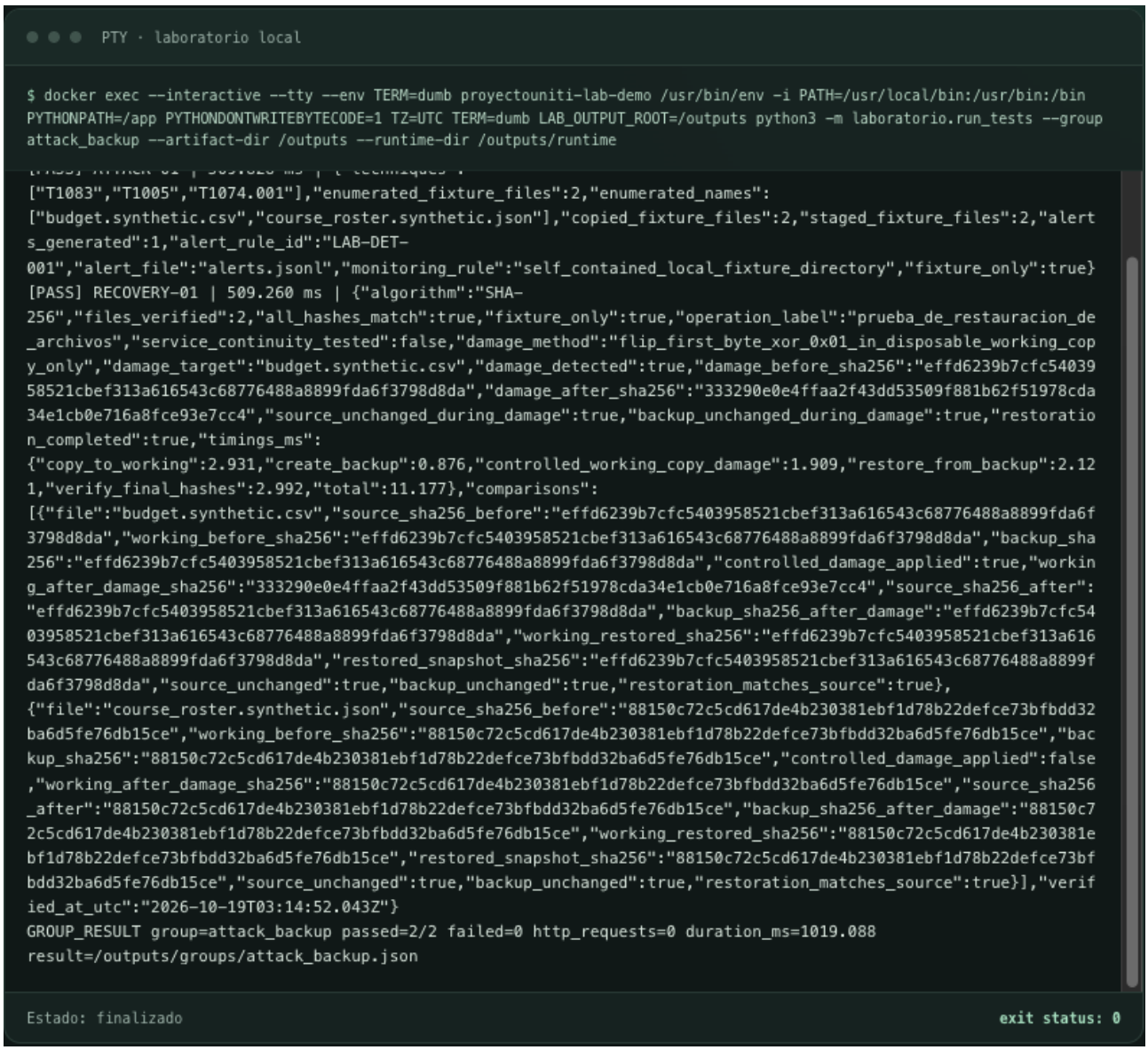


Figura 11: TERM-05. Ejecución real de descubrimiento, recopilación, staging y restauración de archivos.

Fuente: Recorte original sin reconstrucción. La salida extensa tiene desplazamiento; el log íntegro y `resultados.json` conservan los campos no visibles.

Anexo 5. Cyber Kill Chain y controles por etapa

Etapa	Escenario analizado	Control / punto de interrupción	Estado
Reconocimiento	Identificar servicios y personas a partir de presencia pública.	Minimizar información innecesaria, inventario de exposición y detección de exploración.	Analizado; navegación pública no escaneo.
Armamento	Preparar mensaje o artefacto según objetivo.	Protección de correo, reputación y análisis seguro; formación contextual.	Analizado; no se creó malware.
Entrega	Mensaje, enlace o entrada expuesta introduce el intento.	Filtrado, verificación de canal, WAF y límites de entrada según vector.	Analizado; INPUT-01 prueba un control, no entrega adversaria.
Explotación	Aprovechar falla o credencial para acceso indebido.	Parches, MFA, autorización por objeto/rol y reducción de privilegios.	Controles E: AUTH, RBAC, IDOR; sin explotación real.
Instalación	Intento de mantener acceso o introducir componente.	EDR, permisos, ejecución restringida e inventario de cambios.	Analizado; no persistencia instalada.
Comando y control	Canal para recibir instrucciones o transferir información.	Segmentación, control de salida y correlación DNS/proxy.	Analizado; sin C2. El relé PTY es herramienta local autorizada.
Acciones sobre objetivo	Localizar, reunir o alterar información y afectar disponibilidad.	Mínimo acceso, alertas sobre exportación/staging, copias y respuesta.	ATTACK-01 y RECOVERY-01 E sólo archivos ficticios.

Mapa de interrupción

Reconocimiento → Armamento → Entrega → Explotación → Instalación → C2 → Objetivo. Inventario/exposición → correo seguro → validación de entrada → identidad y parcheo → control de ejecución → segmentación/salida → detección y restauración.

La evidencia técnica compartida es TERM-01/02/04/05 (Figuras 7, 8, 10 y 11). Se referencia la misma ejecución sin duplicar imágenes ni fingir siete fases ejecutadas. TI-02/TI-03 sustentan conductas reales externas, pero no todas las etapas de una intrusión institucional demostrada.

Restauración: del daño constatado al estado íntegro

RECOVERY-01 creó una copia de trabajo y un respaldo de dos fixtures. Alteró un byte de la copia de `budget.synthetic.csv`; detectó un hash diferente; comprobó que fuente y respaldo seguían intactos; restauró desde el respaldo; y verificó igualdad final de ambos archivos. La fase de restauración midió 2,121 ms; el conjunto de fases 11,177 ms. Son tiempos locales de archivos pequeños, no RTO institucional ni continuidad del servicio.

```
SHA-256 budget.synthetic.csv
before:   effd6239b7cfc5403958521cbef313a616543c68776488a8899fda6f3798d8da
damaged:  333290e0e4ffaa2f43dd53509f881b62f51978cda34e1cb0e716a8fce93e7cc4
restored: effd6239b7cfc5403958521cbef313a616543c68776488a8899fda6f3798d8da
source_unchanged=true; backup_unchanged=true; files_verified=2
```

Estos valores son transcripción de resultados registrados, no una captura adicional. SHA-256 detecta diferencias respecto de una referencia; no demuestra por sí solo autoría, inmutabilidad o fecha de creación.

Anexo 6. Matriz Zero Trust, roles, usuarios y permisos

Rol propuesto	Permiso por necesidad	Restricción y revisión	Evidencia
Solicitante	Crear solicitud y consultar/obtener sólo documentos propios autorizados.	Verificación de identidad; no editar estado oficial ni leer otros expedientes.	Analogía IDOR/RBAC local; flujo UNA V.
Tramitador	Revisar y actualizar expedientes asignados a su unidad.	Sin gestión global de identidad ni aprobación final incompatible.	Analogía editor local; permisos UNA V.
Responsable académico	Aprobar/emisión según competencia y expediente.	Separación de quien solicita o prepara; trazabilidad obligatoria.	Diseño P, no probado en sistema real.
Administrador OTI	Configuración técnica con cuenta privilegiada separada y acceso temporal.	MFA, justificación, registro y revisión; no privilegio académico por defecto.	RBAC-01/02 local; segregación real V.
Analista CSIRT	Leer eventos y coordinar contención según autorización.	No modificar evidencia ni contenido académico por esa función.	Procedimiento P.
Proveedor	Recurso y ventana contractual expresamente aprobados.	Identidad nominal, MFA, sesión temporal y revocación al terminar.	Contrato/accesos V.

Cuenta de prueba	Rol local	Recurso y decisión comprobada	Caso
Lucia Reader	reader	Lectura A permitida; B no divulgado; administración y edición denegadas.	AUTH-03; IDOR-01; INT-01; RBAC-01.
Cuenta editor	editor	Modificación del objeto asignado permitida.	RBAC-03.
Cuenta admin	admin	Panel administrativo permitido.	RBAC-02.
Sesión de prueba	reader	Tras revocación, el valor anterior no autoriza acceso.	SESSION-01.

Son cuentas ficticias de una aplicación local, no personas ni usuarios de la UNA. Los secretos y valores de sesión no se imprimen ni se incluyen en el informe.

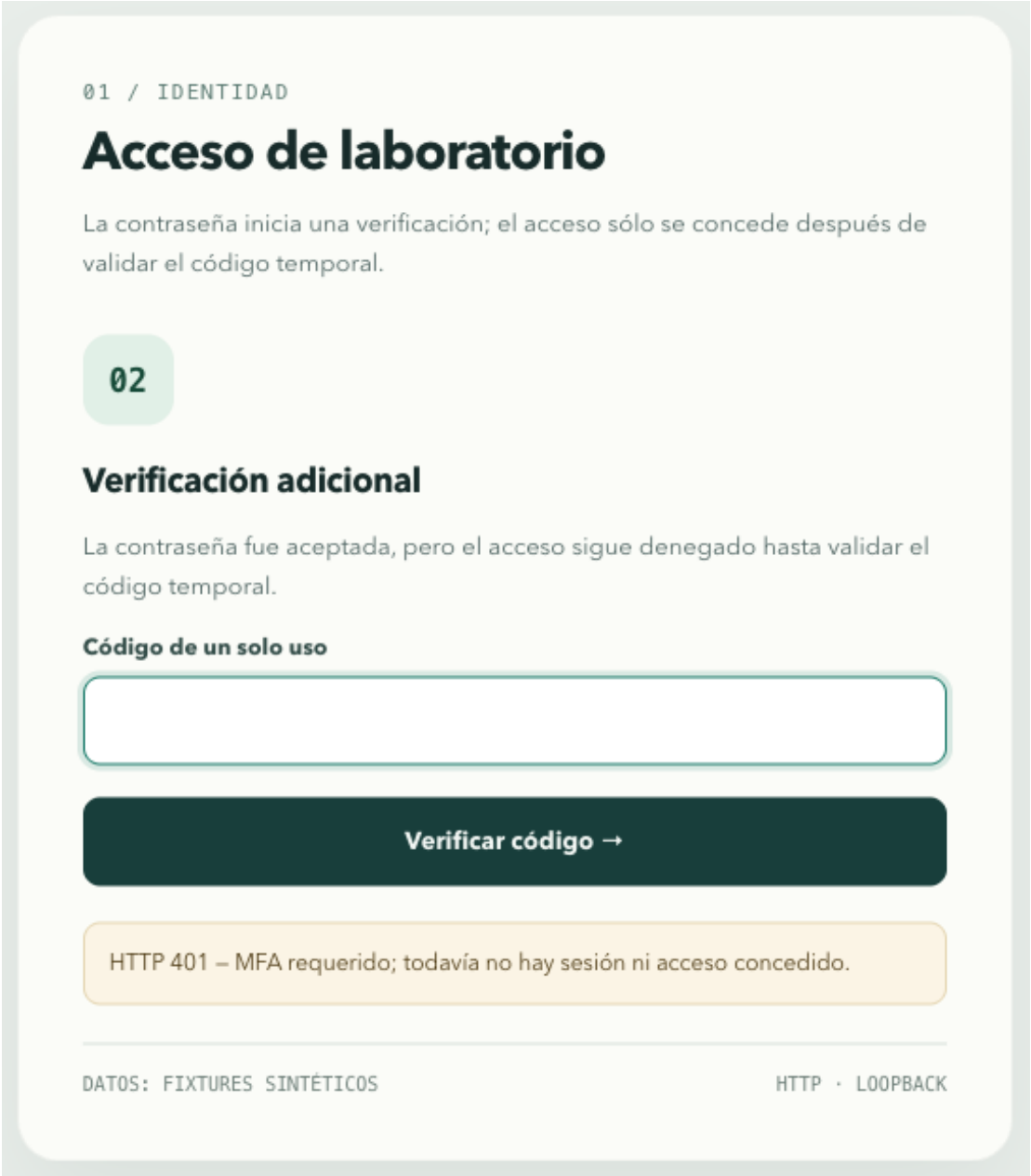


Figura 12: BROWSER-01. Contraseña correcta sin segundo factor: acceso no concedido.
Fuente: Detalle recortado de captura Playwright original sobre aplicación local; respuesta HTTP 401 `mfa_required`.

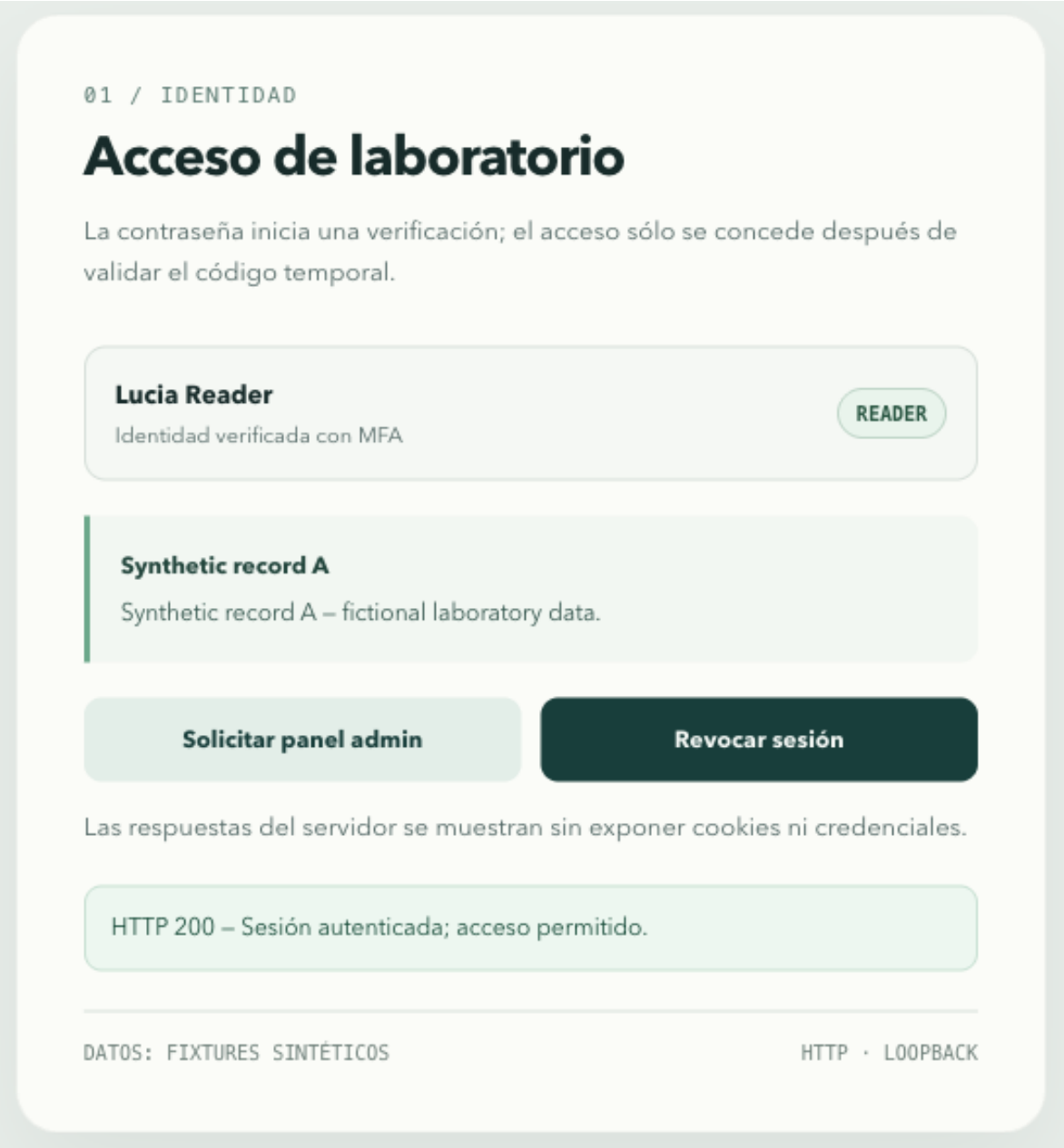


Figura 13: BROWSER-02. Acceso permitido con TOTP y lectura del registro propio.
Fuente: Detalle recortado de la pantalla original, rol lector, HTTP 200; no se expone secreto ni código TOTP.



Figura 14: BROWSER-03. El lector recibe HTTP 403 al solicitar administración.
Fuente: Detalle de captura original de respuesta real del servidor local; no sólo ocultamiento de una opción.

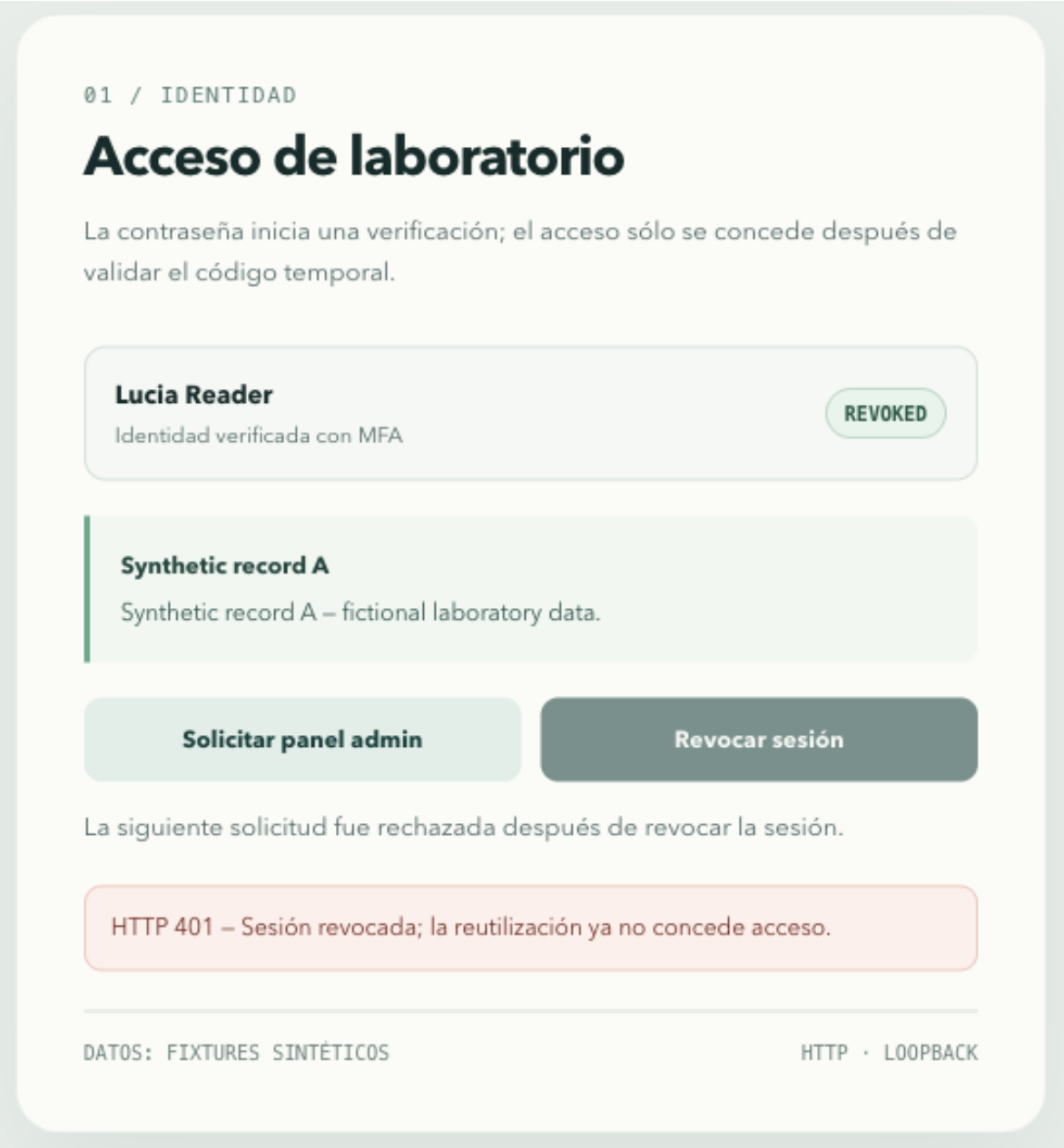


Figura 15: BROWSER-04. La sesión revocada deja de autorizar solicitudes.
Fuente: Detalle recortado de la captura original; revocación HTTP 200 y comprobación posterior HTTP 401.

Anexo 7. Registro de incidentes y procedimiento reproducible

Registro del ejercicio técnico

Los eventos siguientes pertenecen a la práctica local. No son incidentes ocurridos en la UNA ni estadísticas institucionales. Se conserva ID, fuente, activo, clasificación, decisión, evidencia y cierre; un evento bloqueado no se etiqueta automáticamente como compromiso.

Registro	Evento / fuente	Decisión y resultado	Evidencia / cierre
LAB-INC-01	Autenticación sin factor; AUTH-02.	Rechazo esperado 401, sin sesión; no compromiso demostrado.	TERM-01 / BROWSER-01; cerrado conforme.
LAB-INC-02	Solicitud administrativa por lector; RBAC-01.	Rechazo 403; operación no autorizada impedida.	TERM-02 / BROWSER-03; cerrado conforme.
LAB-INC-03	LAB-DET-001 observa dos archivos en staging.	Alerta emitida y revisión de alcance: sólo fixtures autorizados. Evento de ejercicio, no exfiltración.	TERM-05; alerts.jsonl; cerrado con límite documentado.
LAB-INC-04	Alteración controlada de copia de trabajo.	Hash cambia; fuente/backup íntegros; restauración de dos archivos validada.	RECOVERY-01 y verification.json; cerrado conforme.

Los tiempos exactos de inicio, fin y duración por caso están en `resultados.json`; las pruebas finales se ejecutaron el 18/10/2026 en Perú, con marcas del 19/10 en UTC. No se inventa un tiempo de respuesta humana para una prueba automatizada.

Entorno de ejecución

Se utilizó Python 3.12.3, SQLite 3.45.1, Docker Engine 29.5.3, Node.js 24.14.1 y Playwright Core 1.64.1. La sesión técnica utilizó Chrome 155.0.8059.82; la captura de portales registró Chrome 154.0.8037.58. Son sesiones separadas y se preserva la versión de cada una. El contenedor no publicó puertos; la aplicación escuchó en su loopback. Un relé local autorizado permitió el navegador sin conectar pruebas a servicios externos.

La imagen preexistente utilizada fue `marfil-pdf-test:latest`, identificada por configuración SHA-256 `4180697e2ec643227d99f19ffd95f4315e496e5db5192b9ce328a96ce6214310`. No se distribuye esa imagen; por ello, la reproducción exacta del entorno exige disponer de ella. El código sólo usa biblioteca estándar Python y documenta una alternativa oficial fijada por digest; esa alternativa fue consultada, no ejecutada, y cambia el entorno observado. Los manifiestos permiten verificar el código y los fixtures entregados, no garantizar píxeles idénticos en otra plataforma.

Secuencia de comandos

Se distinguen las invocaciones registradas de sus formas normalizadas para reproducción. Las líneas con barras invertidas continúan un mismo comando. Los secretos de fixtures se gestionan dentro del entorno local; no se muestran tokens, cookies ni semillas MFA. El arranque registrado en `runtime/startup.json` fue:

```
LAB_RUNTIME_IMAGE=marfil-pdf-test:latest \
LAB_RUNTIME_IMAGE_ID=sha256:4180697e2ec643227d99f19ffd95f4315e496e5db5192b9ce328a96ce6214310 \
LAB_RUNTIME_IMAGE_SOURCE=preexisting-local-image \
python3 herramientas/lab_capture.py --start-container
```

El helper creó o comprobó la red, verificó la imagen e inició el contenedor. Su argv completo se conserva en `startup.json`. El bloque siguiente es una **expansión normalizada**, con rutas y UID/GID variables para explicar el aislamiento; no una transcripción literal del argv:

```
# 1. Red interna y verificacion del runtime local
docker network create --internal proyectouniti-lab-isolated
docker image inspect --format '{{.Id}}' marfil-pdf-test:latest

# 2. Servicio local, codigo de solo lectura y recursos acotados
docker run --detach --pull=never --rm --name proyectouniti-lab-demo \
  --network proyectouniti-lab-isolated --read-only \
  --cpus=1 --memory=256m --pids-limit=32 \
  --ulimit nofile=64:64 --ulimit fsize=1048576:1048576 \
  --ulimit cpu=90:90 --cap-drop=ALL \
  --security-opt=no-new-privileges \
  --tmpfs /tmp:rw,noexec,nosuid,size=32m,mode=1777 \
  --user "$(id -u):$(id -g)" \
  --mount type=bind,src="$PWD/laboratorio",dst=/app/laboratorio,readonly \
  --mount type=bind,src="$PWD/evidencias/laboratorio",dst=/outputs \
  --workdir /app --entrypoint=/usr/bin/env marfil-pdf-test:latest -i \
  PATH=/usr/local/bin:/usr/bin:/bin HOME=/tmp TMPDIR=/tmp \
  PYTHONPATH=/app PYTHONDONTWRITEBYTECODE=1 LAB_OUTPUT_ROOT=/outputs \
  LAB_DOCKER_NETWORK=proyectouniti-lab-isolated \
  LAB_DOCKER_NETWORK_INTERNAL=true LAB_RUNTIME_IMAGE=marfil-pdf-test:latest \
  LAB_RUNTIME_IMAGE_ID=sha256:4180697e2ec643227d99f19ffd95f4315e496e5db5192b9ce328a96ce6214310 \
  LAB_DOCKER_SERVER_VERSION=29.5.3 TZ=UTC \
  python3 -m laboratorio.app --host 127.0.0.1 --port 8765 \
  --database /tmp/lab.sqlite3 --runtime-dir /outputs/runtime
```

```
# 3. Comando PTY completo del grupo de identidad
docker exec --interactive --tty --env TERM=dumb proyectouniti-lab-demo \
  /usr/bin/env -i PATH=/usr/local/bin:/usr/bin:/bin PYTHONPATH=/app \
  PYTHONDONTWRITEBYTECODE=1 TZ=UTC TERM=dumb LAB_OUTPUT_ROOT=/outputs \
  python3 -m laboratorio.run_tests --group auth_mfa \
  --artifact-dir /outputs --runtime-dir /outputs/runtime
```

La misma invocación PTY se ejecutó reemplazando únicamente el grupo por `rbac_idor`, `integrity_audit`, `size_revocation` y `attack_backup`. Los cinco comandos completos, sin abreviaciones, constan en `resultados.json` y en los logs de cada grupo.

```
# Preparacion reproducible de la dependencia de captura
npm ci --offline --no-audit --no-fund --prefix laboratorio/browser-tools
# Forma normalizada de la invocacion de captura registrada
env -i PATH="$PATH" HOME="$HOME" DOCKER_CONTEXT=desktop-linux \
  node laboratorio/browser-tools/capture.js \
  --base-url http://127.0.0.1:18765 \
  --terminal-url http://127.0.0.1:18766 \
  --output-dir evidencias/laboratorio/capturas

# 5. Preservacion, agregacion y cierre
python3 herramientas/lab_capture.py --collect-server-log
docker exec proyectouniti-lab-demo /usr/bin/env -i \
  PATH=/usr/local/bin:/usr/bin:/bin PYTHONPATH=/app \
  PYTHONDONTWRITEBYTECODE=1 LAB_OUTPUT_ROOT=/outputs TZ=UTC \
  python3 -m laboratorio.finalize --evidence-dir /outputs
docker stop proyectouniti-lab-demo
docker network rm proyectouniti-lab-isolated

# 6. Integridad: ejecutar desde la raiz del proyecto
shasum -a 256 --check evidencias/laboratorio/source_manifest.sha256
```

El script de captura inicia y detiene los relés locales. La agregación mostrada es una forma normalizada del núcleo funcional: la ejecución incorpora también metadatos de imagen y red registrados en los resultados. La preparación offline de Node requiere caché previa; su bloque permite reproducir la dependencia y no es una transcripción auditada dentro de `resultados.json`. Los comandos de reproducción no se cuentan como una segunda corrida: la evidencia de ejecución son los registros y las capturas conservados.

Inventario de evidencia y custodia

Archivo / grupo	Contenido y uso
`resultados.json`	13 casos funcionales y cuatro de navegador; comandos, resultados, UTC, stack y limitaciones.
`evidence_index.json`	Nueve capturas técnicas con IDs, método y procedencia.
`manifest.sha256`	Hashes de 41 archivos de evidencia en la versión final, excluyendo el propio manifiesto.
`source_manifest.sha256`	Hashes de 16 archivos de código/fixtures y herramientas asociadas.
`logs/terminal/`	Salida real de los cinco procesos PTY, sin transcripciones precargadas.
`runtime/`	Estado de arranque, alerta local, copias de trabajo/respaldo/restauración y verificación.
`evidencias/web/indice_web.json`	URLs finales, HTTP, UTC, versión y resultado de navegación.
`terminal-crops.json`	Relación entre originales y recortes: rectángulo y hash de ambos.

Los originales no se editaron. Los recortes de terminal sólo eliminan zonas de navegación para mejorar legibilidad, sin reconstruir salida. El contenido largo puede exceder el área visible; se acompaña con log bruto. La conservación institucional propuesta separará evidencia, permisos de modificación y revisión; un hash local no sustituye una cadena de custodia formal.

Anexo 8. Cronograma anual

El horizonte empieza tras aprobación, no en una fecha ficticia. M1–M12 son meses relativos. Cada actividad tiene una dependencia y un entregable verificable; los recursos humanos son funciones propuestas, no personas contratadas.

Mes	Actividad y dependencia	Responsable	Entregable / aceptación
M1	Aprobar gobierno, designaciones, alcance y canales; obtener línea base.	Alta Dirección/OSCD; OTI.	Acta, RACI, canal publicado y fuentes de datos acordadas.
M2	Conciliar activos, propietarios y proveedores; depende M1.	OTI y dueños.	Inventario verificable; discrepancias registradas.
M3	Clasificar datos/criticidad, modelar sistemas prioritarios y aprobar riesgos.	Dueños; OTI; responsable de datos.	Matrices con aceptación y prioridades.
M4	MFA privilegiado, bajas y recuperación de cuenta; depende inventario identidades.	OTI; RR. HH.	Cobertura por denominador y pruebas de acceso/revocación.
M5	Corregir exposición/parches priorizados, endurecer endpoints y accesos de terceros.	OTI/proveedores.	Cierres de hallazgos con versión y prueba.
M6	Centralizar registros y probar casos de detección; primera revisión semestral.	OTI/CSIRT.	Alertas atendibles, responsables y prueba de correlación.
M7	Segmentar accesos críticos y administración; depende flujos aprobados.	OTI y dueños.	Matriz de flujos; pruebas permitidas/denegadas.
M8	Fortalecer copias segregadas/inmutables y ejecutar recuperación.	OTI/continuidad.	Restauración funcional, tiempos y aceptación del dueño.
M9	Campaña autorizada de phishing y formación por rol.	Capacitación; OSCD.	Reportes agregados, aprendizaje y acciones sin exponer personas.
M10	Ejercicio de incidente y notificación, incluidos datos personales.	CSIRT/legal/dueños.	Línea de tiempo y decisiones legales fundamentadas.
M11	Reevaluar controles y riesgo residual; cerrar dependencias de proveedores.	OTI/OSCD; contratación.	Pruebas de eficacia y planes de mejora.
M12	Revisar perfil CSF, indicadores y continuidad; aprobar siguiente ciclo.	Alta Dirección y dueños.	Informe anual, riesgo aceptado y plan siguiente.

Actividades recurrentes: triage de avisos semanal y urgente por exposición crítica; revisión de alertas en cobertura definida; gestión de cambios y parches mensual; revisión de accesos trimestral; prueba de restauración trimestral y tras cambios relevantes; reporte de indicadores mensual. El presupuesto se formulará por inventario y cobertura: horas de responsables, licencias si se justifican, almacenamiento segregado y capacidad de guardia. No se asignan costos o cantidades sin cotizaciones y línea base.

Anexo 9. Indicadores de ciberseguridad

Indicador	Fórmula / denominador	Fuente y frecuencia	Meta propuesta	Responsable
K01 Inventario	Activos con datos mínimos validados / activos conciliados ×100. No usar filas de catálogo como universo.	Inventario y conciliación; mensual. Base UNA: ND.	100 % críticos al M3; ≥95 % total al M6.	OTI/propietarios.
K02 Evaluación	Sistemas críticos con análisis y tratamiento aprobados / sistemas críticos identificados ×100.	Riesgos/STRIDE; trimestral. Base ND.	100 % al M6.	OTI/dueños.
K03 Vulnerabilidades detectadas	Conteo validado por severidad y activos evaluados; indicar cobertura y duplicados excluidos.	Registro de vulnerabilidades; mensual. Base ND.	Validar 100 % de reportes antes de cierre o escalamiento.	OTI.
K04 Corrección	Vulnerabilidades corregidas dentro del plazo acordado / vulnerabilidades con vencimiento en periodo ×100.	Tickets y prueba de cierre; mensual. Base ND.	≥95 %; excepciones aceptadas por dueño.	OTI/proveedor.
K05 MFA	Trabajadores con MFA habilitado y verificado / trabajadores con cuenta activa en alcance ×100. Reportar privilegiados aparte.	IdP y RR. HH.; mensual. Base ND.	100 % privilegiados M4; ≥95 % resto M8.	OTI/RR. HH.
K06 Phishing detectado	Conteo de mensajes confirmados; tasa de reporte en ejercicio = destinatarios que reportan / mensajes entregados ×100.	Mesa de ayuda/correo; mensual y por ejercicio. Base ND.	Reporte ≥60 % en segundo ejercicio; ajustar tras línea base.	OSCD/capacitación.
K07 Capacitación	Trabajadores que completan evaluación / trabajadores convocados ×100; aprobación por separado.	Asistencia y evaluación; trimestral. Base ND.	≥95 % finalización; ≥80 % aprobación.	Capacitación/RR. HH.
K08 MTTD	Suma(detección − primera actividad confirmada) / incidentes con ambas marcas. Reportar también mediana y alcance.	Línea de tiempo incidentes; mensual. Base ND.	Establecer base M3; reducir 25 % al M12 sobre serie comparable.	CSIRT.
K09 Respuesta	Suma(inicio contención − detección) / incidentes con ambas marcas; no mezclar con recuperación.	Tickets y decisiones; mensual. Base ND.	Decisión críticos ≤2 h en cobertura aprobada.	CSIRT/dueño.
K10 Copias verificadas	Pruebas de restauración íntegras y funcionales / pruebas programadas ×100. Registrar no ejecutadas.	Actas y hashes; trimestral. Base ND.	100 % críticas; fallo genera acción correctiva.	OTI/continuidad.

ND significa no disponible en esta investigación. Los umbrales son metas de planificación sujetas a aprobación y recursos. Un aumento inicial de vulnerabilidades detectadas puede reflejar mejor cobertura; se analiza con severidad, exposición y tiempo de cierre.

Resultados medidos del laboratorio

Medición	Resultado	Límite de interpretación
Casos funcionales conformes	13/13 (100 %)	Casos definidos, no cobertura exhaustiva ni cumplimiento institucional.
Flujos de navegador conformes	4/4 (100 %)	Misma aplicación local con comprobación de respuesta.
Solicitudes funcionales / navegador	34 / 7	41 solicitudes registradas; no prueba de rendimiento.
Staging y alerta local	2 archivos / 1 alerta	Regla sobre fixtures, no actividad adversaria institucional.
Archivos íntegros tras restauración	2/2	Alteración controlada de un archivo; no servicio completo.
Capturas originales	9 técnicas + 5 web	WEB04 sin imagen; no se sustituyó por contenido artificial.
Integridad final	41 evidencias + 16 fuentes técnicas	Manifiestos SHA-256; no firma de autoría ni cadena de custodia externa.

Anexo 10. Plan de capacitación

Tema / periodo	Audiencia y objetivo	Actividad / evaluación	Duración y evidencia
Phishing e ingeniería social / M2 y M9	Personal y usuarios en alcance: verificar remitente/contexto y reportar sin propagar.	Casos de mensajes y segundo canal; ejercicio autorizado en M9.	45 min + ejercicio; respuestas agregadas y tasa de reporte.
Contraseñas y MFA / M3–M4	Personal y administradores: contraseña única, factor y recuperación segura.	Activación guiada y rechazo sin factor; no compartir códigos.	45 min; verificación de habilitación sin guardar secretos.
Datos personales / M3 y M10	Tramitadores, RR. HH. y responsables: acceso por finalidad y mínima divulgación.	Clasificar caso y decidir qué datos compartir/notificar.	60 min; evaluación de decisiones y material revisado.
Correo y navegación segura / M5	Personal: verificar enlaces, adjuntos y canales de actualizaciones.	Reconocer URL y solicitud anómala; reporte por canal institucional.	30 min; cuestionario y caso práctico.
USB y equipos / M5	Personal: no ejecutar medios desconocidos; bloquear pantalla y reportar pérdida.	Caso de dispositivo encontrado y procedimiento de pérdida.	30 min; decisión correcta y registro de participación.
Reporte e incidentes / M6 y M10	Personal y CSIRT: reconocer, registrar y escalar sin destruir evidencia.	Ejercicio de triage con tiempos y roles; verificar notificación condicional.	60 min; ticket y línea de tiempo.
Administración segura / M7	OTI y proveedores autorizados: privilegios, parches, segmentación y logs.	Prueba de acceso permitido/denegado y revisión de cambio.	90 min; evidencia técnica y revisión por par.
Respaldo y restauración / M8 y M11	OTI y dueño del servicio: comprobar integridad y utilidad del estado recuperado.	Restauración controlada y aceptación funcional.	90 min; hashes, tiempos, fallos y acta.

Evaluación: diagnóstico inicial breve, ejercicio por rol y reevaluación; asistencia no equivale a competencia. Se propone aprobación de 80 % y refuerzo focalizado cuando no se alcance. Los reportes se agregan por audiencia; no se difunden nombres ni credenciales. El material se revisará con avisos nuevos y causas de incidentes, evitando campañas genéricas sin relación con el trabajo real.

Glosario de términos y siglas

Término	Significado y uso en este plan
Activo / propietario	Recurso o información que aporta valor; el propietario decide necesidades y acepta el riesgo, mientras el custodio opera.
Amenaza / vulnerabilidad	Suceso o actor capaz de causar daño; condición que puede permitirlo. Un riesgo modelado no confirma una vulnerabilidad.
ANPD / CNSD	Autoridad Nacional de Protección de Datos Personales / Centro Nacional de Seguridad Digital; receptores con competencias y supuestos distintos.
ATT&CK / táctica / técnica	Base MITRE de comportamientos; táctica expresa el propósito, técnica cómo se intenta conseguirlo.
Autenticación / autorización	Verificar identidad frente a decidir si puede realizar una acción sobre un recurso concreto.
CIA o C/I/D	Confidencialidad, integridad y disponibilidad: protección frente a divulgación, modificación o interrupción no autorizadas.
CSF / perfil objetivo	Cybersecurity Framework de NIST; resultados priorizados que se pretende alcanzar, distintos del estado actual.
CSIRT / OSCD / OTI	Equipo de respuesta a incidentes / Oficial de Seguridad y Confianza Digital / Oficina de Tecnologías de la Información. No se presume equivalencia de roles.
CVE / KEV	Identificador de vulnerabilidad / catálogo CISA de vulnerabilidades explotadas; requiere cotejar producto, versión y exposición.
EDR / SIEM / WAF	Detección y respuesta de endpoint / gestión y correlación de eventos / protección de aplicaciones web. Herramientas sin operación y reglas no prueban eficacia.
Fixture	Dato de prueba controlado y repetible. En este trabajo son archivos y cuentas ficticios sobre los que sí se ejecutan operaciones reales.
Hash / SHA-256	Resumen criptográfico para comparar bytes; un cambio altera el resumen. No acredita por sí solo autoría o fecha.
HTTP 200/201	Respuestas de operación correcta/recurso creado en los casos observados.
HTTP 401/403/404/413	No autenticado / acción prohibida / recurso no revelado o no encontrado / contenido demasiado grande. Su significado se interpreta con el contrato del caso.
IAM / IdP / MFA	Gestión de identidades y acceso / proveedor de identidad / autenticación de múltiples factores.
IDOR	Referencia directa a objeto sin autorización adecuada: cambiar un identificador no debe permitir leer o modificar información ajena.
IOC / inteligencia	Indicador de compromiso / información analizada con contexto, confianza y acción. Un IOC histórico no prueba compromiso actual.
MTTD / MTTR	Tiempo medio de detección / de respuesta o recuperación según definición explícita; este plan mide inicio de contención por separado.
Phishing / smishing	Engaño por mensajes o SMS para provocar una acción; suplantación visual no es evidencia de legitimidad.
PTY	Pseudoterminal que conecta un proceso real con una interfaz de terminal; aquí sostiene las capturas de comandos ejecutados.
RaaS / ransomware	Ransomware como servicio / extorsión que puede incluir cifrado y robo de datos. Restaurar no elimina necesariamente la fuga.
RBAC / privilegio mínimo	Control por roles / otorgar únicamente acciones y recursos necesarios, con revisión y revocación.
Riesgo inherente / residual	Riesgo antes del tratamiento / que permanece tras controles evaluados. En la matriz, el residual es objetivo propuesto.
RPO / RTO	Pérdida de datos tolerable expresada en tiempo / tiempo objetivo de recuperación del servicio; deben acordarse por proceso.
Staging / exfiltración	Preparación o reunión de datos / salida no autorizada. El laboratorio ejecutó staging local, no exfiltración.
STRIDE	Suplantación, manipulación, repudio, divulgación, denegación y elevación de privilegios; taxonomía de modelado.
TOTP	Contraseña temporal basada en tiempo, RFC 6238. El laboratorio usa periodos de 30 s; no es resistente al phishing por sí misma.
UTC / Zero Trust	Tiempo universal coordinado / arquitectura sin confianza implícita por ubicación; verificar acceso a recursos según contexto.

Trazabilidad de cobertura

Producto solicitado	Ubicación y evidencia
Datos, introducción, finalidad, objetivos, alcance	Secciones I–V; método, límites y normativa.
Inventario y criticidad	Sección VI; Anexos 1–2; cinco capturas institucionales y estados D/V.
STRIDE y capturas	Sección VII; Anexo 3; 12 escenarios, TERM-01–04 y casos funcionales.
Threat Intelligence	Sección VIII; boletín TI-2026-01, cuatro avisos e IOC con vigencia/contexto.
ATT&CK y capturas	Sección IX; Anexo 4; técnicas ejecutadas y analizadas separadas, TERM-05.
Kill Chain y capturas	Sección X; Anexo 5; siete etapas, controles y evidencia referenciada.
Zero Trust y capturas	Sección XI; Anexo 6; permisos, cuatro pantallas y revocación.
NIST CSF 2.0 y controles	Secciones XII–XIII; seis funciones y 12 controles.
Incidentes / registro	Sección XIV; Anexo 7; procedimiento, marco legal, eventos de laboratorio y comandos.
Cronograma / indicadores / capacitación	Secciones XV–XVI; Anexos 8–10; metas y resultados locales separados.

La numeración de secciones es correlativa: la consigna repite XII para NIST y controles; aquí se conserva su contenido como XII y XIII y se desplazan los posteriores sin omitir productos.

Trazabilidad entre riesgo, control y resultado

Las relaciones son analíticas y muchos-a-muchos: una técnica puede afectar varios escenarios y un control puede contribuir a más de un resultado CSF. No se equipara una operación legítima de prueba con una intrusión.

Escenario	ATT&CK / Kill Chain	Control y resultado NIST	Prueba / indicador
S01 / identidad	T1078 analizada; oportunidad de interrupción en acceso/explotación.	C01; PR.AA-03: autenticar antes de conceder acceso.	AUTH-01–03; K05 cobertura MFA.
S03,S07,S11	Riesgos de manipulación, divulgación y privilegios; no se fuerza una técnica equivalente.	C02; PR.AA-05: permisos revisados y mínimo privilegio por recurso.	INT-01, IDOR-01, RBAC; K02 evaluación.
S05 / auditoría	Observación transversal, no una fase única de ataque.	C03; DE.AE-02: correlacionar y analizar eventos.	AUDIT-01; K08 sólo con serie de incidentes.
S08 / información	T1083/T1005/T1074.001 ejecutadas en fixtures; acciones sobre objetivo.	C08; DE.AE-02 como objetivo de análisis; la regla no valida monitoreo de red DE.CM-01.	ATTACK-01; una alerta, sin exfiltración.
S04,S10 / recuperación	Impacto y acciones sobre objetivo; no se ejecutó ransomware.	C11; RC.RP-01: recuperación iniciada desde respuesta.	RECOVERY-01; K10 restauraciones verificadas.
S12 / sesión	T1078 sólo riesgo de abuso; contención transversal.	C01/C02; PR.AA-03 y RS.MA-01 como objetivos coordinados.	SESSION-01; K09 contención institucional por medir.

Referencias

[1] Universidad Nacional del Altiplano. *Portal institucional y catálogo público de servicios*. Sin fecha editorial. https://portal.unap.edu.pe/. Consulta: 18/10/2026. Servicios: https://campus.unap.edu.pe/; https://tramites.unap.edu.pe/; https://aulavirtual2.unap.edu.pe/; https://portal.unap.edu.pe/repositorio-institucional.

[2] Universidad Nacional del Altiplano. *Reglamento de Organización y Funciones, aprobado por RR 2212-2025-R-UNA*. 2025. Arts. 53, 70–71, pp. impresas 53–54 para OTI. https://portal.unap.edu.pe/documento/reglamento-de-organizacion-y-funciones. Copia: `fuentes/documentos/ROF-2025-RR-2212.pdf`.

[3] NIST. *The NIST Cybersecurity Framework (CSF) 2.0*. CSWP 29, 26/02/2024. https://doi.org/10.6028/NIST.CSWP.29.

[4] NIST. *Zero Trust Architecture*. SP 800-207, 11/08/2020. https://csrc.nist.gov/pubs/sp/800/207/final.

[5] NIST. *Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile*. SP 800-61 Rev. 3, 03/04/2025. https://csrc.nist.gov/pubs/sp/800/61/r3/final.

[6] Microsoft. *Threats: Microsoft Threat Modeling Tool (STRIDE)*. Microsoft Learn. https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats. Consulta: 18/10/2026.

[7] Lockheed Martin. *Cyber Kill Chain; Gaining the Advantage*. Sin fecha editorial en página. https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html.

[8] MITRE. *ATT&CK Version History*. v20.0 desde 13/10/2026. https://attack.mitre.org/resources/versions/.

[9] MITRE. *File and Directory Discovery, T1083*. ATT&CK Enterprise v20. https://attack.mitre.org/versions/v20/techniques/T1083/.

[10] MITRE. *Data from Local System, T1005*. ATT&CK Enterprise v20. https://attack.mitre.org/versions/v20/techniques/T1005/.

[11] MITRE. *Data Staged: Local Data Staging, T1074.001*. ATT&CK Enterprise v20. https://attack.mitre.org/versions/v20/techniques/T1074/001/.

[12] MITRE. *Valid Accounts, T1078*. ATT&CK Enterprise v20. https://attack.mitre.org/versions/v20/techniques/T1078/.

[13] MITRE. *Phishing, T1566*. ATT&CK Enterprise v20. https://attack.mitre.org/versions/v20/techniques/T1566/.

[14] Presidencia del Consejo de Ministros. *Decreto de Urgencia 007-2020, Marco de Confianza Digital*. 09/01/2020. https://www.gob.pe/institucion/pcm/normas-legales/395322-007-2020.

[15] Presidencia del Consejo de Ministros. *DS 126-2025-PCM y Reglamento del DU 007-2020*. 04/11/2025. Arts. 11, 31–34. https://www.gob.pe/institucion/pcm/normas-legales/7370829-126-2025-pcm.

[16] Congreso de la República / ANPD. *Ley 29733, Ley de Protección de Datos Personales*. 03/07/2011. https://www.gob.pe/institucion/anpd/normas-legales/2018427-29733-2011.

[17] Ministerio de Justicia y Derechos Humanos. *DS 016-2024-JUS, Reglamento de la Ley 29733*. 30/11/2024. Art. 34. https://www.gob.pe/institucion/anpd/normas-legales/6554453-16-2024-jus.

[18] CISA y organismos asociados. *Chinese Government-linked Cyber Threat Actors Combine Automated and Hands-on Hacking Tools to Steal Sensitive Data*. AA26-281A, 08/10/2026. https://www.cisa.gov/news-events/cybersecurity-advisories/aa26-281a.

[19] CISA. *CISA Urges Patching Critical Vulnerability in BeyondTrust Remote Support*. 16/10/2026. https://www.cisa.gov/news-events/alerts/2026/10/16/cisa-urges-patching-critical-vulnerability-beyondtrust-remote-support.

[20] CISA, FBI, DC3, NSA, USSS y KNPA. *#StopRansomware: Gunra Ransomware*. AA26-222A, 10/08/2026. https://www.cisa.gov/news-events/cybersecurity-advisories/aa26-222a.

[21] FBI/CISA. *Cyber Threat Actors Use a Variety of Techniques to Target Election and Campaign Officials*. I-101626-PSA, 16/10/2026. https://www.ic3.gov/PSA/2026/PSA261016.

[22] IETF. *RFC 6238: TOTP: Time-Based One-Time Password Algorithm*. Mayo de 2011, apéndice B. https://www.rfc-editor.org/rfc/rfc6238.

[23] Microsoft. *Playwright: Screenshots*. Documentación técnica. https://playwright.dev/docs/screenshots. Consulta: 18/10/2026.

[24] MITRE. *Exploitation for Privilege Escalation, T1068*. ATT&CK Enterprise v20. https://attack.mitre.org/versions/v20/techniques/T1068/.

[25] MITRE. *Remote Services, T1021*. ATT&CK Enterprise v20. https://attack.mitre.org/versions/v20/techniques/T1021/.